
ISO/IEC 42001:2023

Plain-Language Control and Audit Guide

What every requirement means, why it exists, how to audit it, what evidence to collect, how to document it, and how to report it.

Coverage

Clauses 4 through 10, the management system requirements.
Annex A, all 38 controls across the nine categories.

Audience

Internal auditors, control owners, compliance analysts, and anyone who has to explain an AI governance requirement to somebody who does not work in AI.

Before You Use This Document

This is a companion guide, not a copy of the standard.

ISO/IEC 42001:2023 is a copyrighted publication of ISO and IEC. Nothing in this document reproduces the text of the standard. Every requirement here is described in original wording, using the official clause and control numbering as reference points only. Your organization still needs a licensed copy of ISO/IEC 42001:2023, including its Annex B implementation guidance. Where this guide and the standard appear to differ, the standard governs.

What this guide does

It takes each requirement in ISO/IEC 42001:2023 and answers six questions about it, in the same order every time:

1. **What the control asks for.** The requirement in ordinary language, with no assumed background.
2. **Why it exists.** The failure it is there to prevent. Auditors who understand intent write better findings than auditors who only know the wording.
3. **How to audit it.** Specific test steps, in the order you would actually perform them.
4. **Evidence to collect.** Named artifacts. Not “documentation” but the actual thing to request.
5. **How to document it.** What belongs in the workpaper so a reviewer can follow your reasoning without re-performing your work.
6. **Executive summary treatment.** Suggested language if the item fails or rates high risk, written for an audience that does not read control numbers.

On vocabulary

Technical terms are defined the first time they appear, shown like [this](#), and collected in the glossary. If you hit a term that is not defined, that is a defect in this document; note it and it will be fixed in the next revision.

Navigating this document

Each part opens with a quick-reference table. Every reference number and title in those tables is a live link to the full entry, so the tables work as a jump menu rather than just a contents list. Entries also appear in the PDF bookmark panel, and the index at the back links back into the text.

Link colour carries meaning, and the rule here differs from the companion ISO/IEC 27001 guide for a reason worth stating. In that document the AI marker was useful because it identified the few places AI governance attached to an otherwise non-AI standard. Here every control is about AI, so the same marker would apply to all 67 entries and tell you nothing.

Blue

The requirement has a recognizable ISO/IEC 27001 counterpart. Your existing ISMS evidence and testing is a starting point. This does not mean the requirement is satisfied — it means you are not beginning from a blank page.

Orange, marked ^{AI}

The requirement has no meaningful ISO/IEC 27001 counterpart. An organization already certified to 27001 cannot reuse existing evidence here and must produce net-new work. Twenty-five of the sixty-seven entries fall into this category, and they are concentrated in impact assessment (A.5), data (A.7), and use (A.9).

If you are scoping an integrated audit against both standards, the orange entries are your actual workload. The marker letters are printed as well as coloured, so the distinction survives greyscale printing and does not depend on colour vision. The classification is a judgment, not something the standard states; it is held in a single file in the source and can be re-scoped without touching any content.

One entry, one page

Every clause and control begins at the top of a fresh page and is complete before the next one starts. This wastes some paper and makes the document longer than it needs to be. It also means you can print a single control and hand it to the person who owns it, which is what these documents actually get used for.

On the audit steps

The steps assume a first-party or second-party audit, meaning an internal audit or a customer auditing a supplier. Two cautions specific to this standard.

First, a great deal of AI governance auditing is performed by people who cannot evaluate what they are looking at. Assessing whether a validation approach was sound, or whether a dataset was representative, requires competence that general audit training does not provide. Where you lack it, say so in the workpaper and scope the test to what you can actually support, rather than accepting a demonstration you are not equipped to challenge.

Second, this standard's characteristic failure mode is a programme that produces excellent documentation and changes nothing. Policies, registers, and completed impact assessment templates can all exist while no AI system was ever delayed, modified, or rejected. Several tests in this guide are built around a single question — when did this process last change an outcome — and it is worth asking early.

Three definitions you need before anything else

Role

The organization's position relative to an AI system: developing it, providing it to others, or using one built by somebody else. Determined under Clause 4.1. Obligations follow the role, and most organizations occupy more than one. Role misclassification is the single most common cause of an under-scoped AI programme.

Nonconformity

A failure to meet a requirement. A *major* nonconformity means a requirement is absent, or a failure is

widespread, or it puts the reliability of the whole system in doubt. A *minor* nonconformity is an isolated lapse in a system that otherwise works. Certification is normally blocked by a major and not by a minor.

Impact assessment

An assessment of what an AI system does to the people subject to it. Distinct from risk assessment, which assesses what threatens the organization. A system can present no risk to the organization and still cause serious harm, because the harmed party is not the organization. Where you find the two merged into one document, the requirement is unmet however thorough that document is.

How to read the executive summary sections

Every entry ends with suggested reporting language. It is deliberately written to avoid three habits that get security findings ignored: control numbers in the first sentence, adjectives about maturity, and recommendations that amount to “do it better.” Each one names a specific consequence and, where possible, attaches a number. Adapt the wording; keep the structure.

Contents

Before You Use This Document	ii
1 The Management System: Clauses 4 to 10	1
4.1 Understanding the organization and its context	3
4.2 Understanding the needs and expectations of interested parties	5
4.3 Determining the scope of the AI management system	6
4.4 AI management system	7
5.1 Leadership and commitment	8
5.2 AI policy	9
5.3 Roles, responsibilities and authorities	10
6.1.1 Actions to address risks and opportunities: general	11
6.1.2 AI risk assessment	12
6.1.3 AI risk treatment	13
6.1.4 AI system impact assessment	14
6.2 AI objectives and planning to achieve them	15
6.3 Planning of changes	16
7.1 Resources	17
7.2 Competence	18
7.3 Awareness	19
7.4 Communication	20
7.5.1 Documented information: general	21
7.5.2 Creating and updating documented information	22
7.5.3 Control of documented information	23
8.1 Operational planning and control	24
8.2 AI risk assessment	25
8.3 AI risk treatment	26
8.4 AI system impact assessment	27
9.1 Monitoring, measurement, analysis and evaluation	28
9.2 Internal audit	29
9.3 Management review	30
10.1 Continual improvement	31
10.2 Nonconformity and corrective action	32
2 Annex A.2: Policies Related to AI	33
A.2.2 AI policy	34
A.2.3 Alignment with other organizational policies	35
A.2.4 Review of the AI policy	36
3 Annex A.3: Internal Organization	37
A.3.2 AI roles and responsibilities	38

A.3.3	Reporting of concerns	39
4	Annex A.4: Resources for AI Systems	40
A.4.2	Resource documentation	41
A.4.3	Data resources	42
A.4.4	Tooling resources	43
A.4.5	System and computing resources	44
A.4.6	Human resources	45
5	Annex A.5: Assessing Impacts of AI Systems	46
A.5.2	AI system impact assessment process	47
A.5.3	Documentation of AI system impact assessments	48
A.5.4	Assessing AI system impact on individuals or groups of individuals	49
A.5.5	Assessing societal impacts of AI systems	50
6	Annex A.6: AI System Life Cycle	51
A.6.1.2	Objectives for responsible development of AI systems	52
A.6.1.3	Processes for responsible AI system design and development	53
A.6.2.2	AI system requirements and specification	54
A.6.2.3	Documentation of AI system design and development	55
A.6.2.4	AI system verification and validation	56
A.6.2.5	AI system deployment	57
A.6.2.6	AI system operation and monitoring	58
A.6.2.7	AI system technical documentation	59
A.6.2.8	AI system recording of event logs	60
7	Annex A.7: Data for AI Systems	61
A.7.2	Data for development and enhancement of AI systems	62
A.7.3	Acquisition of data	63
A.7.4	Quality of data for AI systems	64
A.7.5	Provenance of data used in AI systems	65
A.7.6	Data preparation	66
8	Annex A.8: Information for Interested Parties	67
A.8.2	System documentation and information for users	68
A.8.3	External reporting	69
A.8.4	Communication of incidents	70
A.8.5	Information for interested parties	71
9	Annex A.9: Use of AI Systems	72
A.9.2	Processes for responsible use of AI systems	73
A.9.3	Objectives for responsible use of AI systems	74
A.9.4	Intended use of the AI system	75
10	Annex A.10: Third-Party and Customer Relationships	76
A.10.2	Allocating responsibilities	77
A.10.3	Suppliers	78
A.10.4	Customers	79
	Glossary	80
	Index of Terms and Concepts	83

CHAPTER 1

The Management System: Clauses 4 to 10

Twenty-nine requirements that build and run the AI management system itself. They are not optional and none of them can be excluded, and certification audits fail here far more often than they fail on Annex A, because organizations treat these clauses as paperwork around the real controls.

For an AI management system the clauses carry weight they do not carry elsewhere. Clause 4 asks you to determine the organizational context and the role you occupy, which for AI means deciding whether you are a provider, a developer, or a user of systems built by others – a determination that changes what the rest of the standard asks of you. Clause 6 covers the AI risk assessment and the AI system impact assessment, and the second of those has no counterpart in an information security management system.

A note on numbering: this guide follows the standard's clause numbering exactly, so 6.1.2 here is 6.1.2 in the standard. Sub-clauses carrying no independently auditable requirement are folded into their parent.

Quick reference: Clauses 4 to 10

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
4.1	Understanding the organization and its context	Context analysis document with version and revision history
4.2	Understanding the needs and expectations of interested parties	Interested party and requirements register
4.3	Determining the scope of the AI management system	Scope statement, approved, dated, and versioned
4.4	AI management system	AIMS manual or equivalent describing processes and their interactions
5.1	Leadership and commitment	Management review minutes recording decisions and assigned actions
5.2	AI policy	Approved AI policy with approver, date, and version
5.3	Roles, responsibilities and authorities	Roles and responsibilities matrix covering the AI lifecycle
6.1.1	Actions to address risks and opportunities: general	Register covering AIMS-level risks and opportunities
6.1.2	AI risk assessment	Documented AI risk assessment methodology with acceptance criteria
6.1.3	AI risk treatment	Statement of Applicability covering all 38 Annex A controls, approved and versioned
6.1.4 ^{AI}	AI system impact assessment	Documented AI system impact assessment process
6.2	AI objectives and planning to achieve them	Documented objectives at corporate and functional levels

Ref	Title	Primary evidence
6.3	Planning of changes	Change plans dated before implementation
7.1	Resources	Resourcing or capacity analysis for AI governance
7.2	Competence	Competence requirements per AI-relevant role
7.3	Awareness	Awareness content covering the three required elements
7.4	Communication	Communication plan covering internal and external audiences
7.5.1	Documented information: general	Master document register for the AIMS
7.5.2	Creating and updating documented information	Sampled documents with visible metadata
7.5.3	Control of documented information	Access control lists for the AIMS repository
8.1	Operational planning and control	Operational procedures with stated frequencies
8.2	AI risk assessment	Assessment schedule and records of actual performance
8.3	AI risk treatment	Risk treatment plan with original and current target dates
8.4 AI	AI system impact assessment	Completed impact assessments with dates
9.1	Monitoring, measurement, analysis and evaluation	Measurement plan with metrics, methods, frequencies, and owners
9.2	Internal audit	Internal audit programme covering the full cycle
9.3	Management review	Review schedule and actual meeting dates
10.1	Continual improvement	Improvement register with triggers and outcomes
10.2	Nonconformity and corrective action	Nonconformity and corrective action register covering all sources

4.1 Understanding the organization and its context

WHAT THE CONTROL ASKS FOR

Write down what your organization does, the environment it operates in, and the internal and external factors that affect whether your AI management system can achieve what it is meant to achieve. This clause carries an extra requirement that has no equivalent in other management system standards: you must determine the **role or roles** your organization plays in relation to each AI system. The roles include developing AI systems, providing them to others, and using systems built by someone else. Most organizations play more than one.

WHY IT EXISTS

Your obligations depend almost entirely on which role you occupy. An organization that builds a model carries responsibilities for training data and design that a pure user does not, while a user carries responsibilities for deployment context and monitoring that a developer cannot discharge on their behalf. Organizations that never determine their role end up either claiming obligations they cannot meet or missing obligations that are unambiguously theirs.

HOW TO AUDIT IT

1. Obtain the context record and confirm it exists as documented information rather than as shared understanding.
2. Verify the role determination specifically. Ask for the list of AI systems and the organization's role for each. A single blanket role statement covering a diverse portfolio is almost always wrong.
3. Test the role determination against reality. An organization calling itself a user while fine-tuning models on its own data is doing more than using, and the obligations follow the activity rather than the label.
4. Check that context covers the factors that actually bear on AI: regulatory developments, skills availability, data quality, vendor dependencies, and public expectations. Compare the record against the business as it is now, looking for AI systems adopted since it was last updated.
5. Trace forward. Pick two context factors and confirm each appears in the risk assessment or the impact assessment.
6. Interview a senior leader outside the AI function and compare their description of the organization's AI position to the document.

EVIDENCE TO COLLECT

- Context analysis document with version and revision history
- Inventory of AI systems with the organization's determined role for each
- Register of applicable laws, regulations, and guidance relating to AI
- Workshop or meeting records showing who contributed
- Strategy documents or board material used as input
- Evidence of review following the adoption of a new AI system

HOW TO DOCUMENT IT

Record the role determination per AI system in a table, with your own assessment of whether the recorded role matches the activity you observed. This is the highest-value test in the clause and it frequently produces a finding on its own. Note the date of the last context review against the date of the most recent AI system adoption, since the gap between them is usually revealing.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has not determined its role for each of the AI systems it operates, and for a named system it is acting as a developer while managing the system as though it were only a user. State

the obligations that follow from the actual role and are currently unmet. Role misclassification is the cleanest way to explain why an AI governance programme is under-scoped.

4.2 Understanding the needs and expectations of interested parties

WHAT THE CONTROL ASKS FOR

Identify the parties relevant to the AI management system and record what each of them requires. For AI this population is wider than for most management systems: alongside customers, regulators, and employees it includes the people affected by the system's outputs, who may have no relationship with your organization at all and no ability to raise a concern.

WHY IT EXISTS

AI systems make or influence decisions about people who did not choose to interact with them. Those people are interested parties whether or not they know the system exists. If your register only contains parties who can complain, you will systematically miss the ones most exposed to harm, and your impact assessments will inherit that blind spot.

HOW TO AUDIT IT

1. Obtain the register and confirm it records specific requirements per party, not just a list of party names.
2. Check whether affected individuals and groups appear, distinct from customers and users. Their absence is the defining failure of this clause in AI contexts.
3. Verify regulatory requirements are recorded specifically rather than by naming a regulation.
4. Sample customer contracts for AI-related commitments, including accuracy claims, explainability obligations, and restrictions on training use of customer data.
5. Check how the requirements of parties who cannot speak for themselves were determined. Look for consultation, research, or proxy representation rather than assumption.
6. Trace two requirements through to a control, a risk entry, or an impact assessment.
7. Confirm a defined trigger and owner for keeping the register current.

EVIDENCE TO COLLECT

- Interested party and requirements register
- Identification of affected individuals and groups per AI system
- Records of consultation or research used to determine their requirements
- Customer contracts containing AI-related commitments
- Applicable regulatory obligations mapped to requirements
- Review log with dates and owner

HOW TO DOCUMENT IT

State explicitly whether affected persons are represented in the register and, if so, how their requirements were established. Record the method, because assumption dressed as consultation is common and only visible when you ask for the underlying evidence. List traced requirements with where each landed.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the people affected by the organization's AI systems are not identified as interested parties, so their requirements have never been established and could not be considered in any impact assessment. This is a substantive gap rather than an administrative one and it undermines the impact assessment process downstream.

4.3 Determining the scope of the AI management system

WHAT THE CONTROL ASKS FOR

Define and document the boundaries of the **AIMS**, the AI management system. The scope must state which AI systems, business units, locations, and activities are covered, and must account for the context, the interested party requirements, and the relationships with third parties who develop or operate AI on your behalf.

WHY IT EXISTS

Scope determines what your certificate means. AI scope is harder to draw than information security scope because AI capability arrives embedded in tools nobody classified as AI: a recruitment platform with ranking, a service desk with routing, a spreadsheet add-in with generation. A scope drawn around the AI the organization built will miss most of the AI it uses.

HOW TO AUDIT IT

1. Read the scope statement and test whether it lets you determine, from the words alone, whether a given system is in or out.
2. Test the boundary against embedded AI. Ask how the organization identified AI capability inside procured software, and check that method against a sample of its major platforms.
3. Examine exclusions and the dependencies they create. An excluded system whose output feeds an in-scope decision is not meaningfully excluded.
4. Check that third-party developed or operated AI is addressed, since responsibility does not transfer with the work.
5. Compare the documented scope to what the organization tells customers and to any published AI statements.
6. Confirm the scope is available as documented information with a version and approval.

EVIDENCE TO COLLECT

- Scope statement, approved, dated, and versioned
- AI system inventory showing in-scope and out-of-scope determination
- Method used to identify AI capability within procured software
- Justification for exclusions with dependency analysis
- Third-party AI arrangements and their scope treatment
- Customer-facing statements about AI governance coverage

HOW TO DOCUMENT IT

Record the method used to find embedded AI and test it yourself against two or three major procured platforms, documenting what you found. Organizations consistently under-count AI in this category, and demonstrating it with a specific example is far stronger than observing that the method is weak. Reproduce the scope statement verbatim and record each boundary test separately.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the scope covers only AI the organization built, while the majority of AI influencing its decisions arrives inside purchased software and sits outside the management system entirely. Name two examples. This reframes scope from a documentation question into a coverage question, which is what it actually is.

4.4 AI management system

WHAT THE CONTROL ASKS FOR

Establish, implement, maintain, and continually improve the AI management system, including the processes it needs and how those processes interact. This is the umbrella requirement that the remaining clauses fill in, and it is tested by asking whether the system behaves as a connected system rather than as a collection of separate artifacts.

WHY IT EXISTS

AI governance programmes are unusually prone to producing impressive documents that change nothing. A policy, a register, and a completed impact assessment template can all exist while no AI system was ever modified, delayed, or rejected as a result. This clause gives the auditor authority to report that pattern even when each individual requirement appears satisfied.

HOW TO AUDIT IT

1. Ask the AIMS owner to walk you through how a newly proposed AI system travels from idea to approval to deployment to monitoring, naming who is accountable at each step.
2. Trace one system end to end through that path, using dates.
3. Look for the decision point. Ask when the process last stopped, delayed, or materially changed an AI system. A governance process that has never said no is worth examining closely.
4. Check for orphan processes: impact assessments nobody reads, registers nobody updates, monitoring output nobody reviews.
5. Compare document modification dates for evidence of continuous operation versus pre-audit reconstruction.
6. Ask what the AIMS does differently than a year ago and request the evidence behind the answer.

EVIDENCE TO COLLECT

- AIMS manual or equivalent describing processes and their interactions
- One traced AI system with its full governance lifecycle record and dates
- Records of AI systems delayed, modified, or rejected through the process
- Document metadata showing edit and approval dates over time
- Evidence of improvements and their triggers

HOW TO DOCUMENT IT

Present the end to end trace as a dated timeline; it is usually the most persuasive single workpaper in the engagement. Record the answer to the question about when governance last changed an outcome, close to verbatim, along with the supporting evidence or its absence.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the AI governance process has never delayed, modified, or prevented the deployment of an AI system, which suggests it is documenting decisions rather than informing them. Support with the traced example and its dates. Executives understand the distinction between a process that reviews and a process that only records.

5.1 Leadership and commitment

WHAT THE CONTROL ASKS FOR

Top management must lead the AI management system rather than approve it. Specifically they must ensure the AI policy and objectives are compatible with the organization's strategic direction, integrate AIMS requirements into business processes, provide the necessary resources, communicate the importance of effective AI management, ensure the system achieves its intended outcomes, and support other managers in leading within their areas.

WHY IT EXISTS

AI adoption is usually driven by business urgency and competitive pressure, which means the governance function is frequently positioned as an obstacle. Without visible leadership authority, the AI governance team ends up reviewing decisions that have already been made and funded. This clause makes the absence of that authority a formal finding rather than a private frustration.

HOW TO AUDIT IT

1. Interview two or three members of top management separately. Ask what the organization's AI objectives are and how AI governance supports the strategy.
2. Test integration into business processes. Check whether AI governance appears in project intake, procurement, and change management, or is invoked after commitments are made.
3. Compare resources requested by the AI governance function against resources approved, across at least two cycles.
4. Review management review records for decisions and directives rather than attendance.
5. Ask the AIMS owner where they lack the authority to stop or modify an AI initiative, then check whether that gap was escalated and what happened.
6. Look at whether AI governance sits at a level with standing relative to the functions deploying AI, since a governance function reporting into the team it governs is structurally compromised.

EVIDENCE TO COLLECT

- Management review minutes recording decisions and assigned actions
- Budget requests and approvals for AI governance across two or more cycles
- Project intake, procurement, and change procedures showing AI governance gates
- Organizational chart showing reporting lines for AI governance
- Leadership communications on AI governance with dates and audiences
- Escalation records where authority gaps were raised

HOW TO DOCUMENT IT

Present resourcing as a requested-versus-approved table by cycle. Record the reporting line for AI governance explicitly, since structural independence is objectively verifiable and frequently the real cause of the findings elsewhere in the report. Describe behaviour rather than characterizing commitment.

EXECUTIVE SUMMARY TREATMENT

Suggested language: AI governance is engaged after AI initiatives are approved and funded, and the function reports into the same leadership accountable for delivering them, so it has no practical ability to stop or modify a system. Structural framing is more actionable than describing leadership engagement as insufficient.

5.2 AI policy

WHAT THE CONTROL ASKS FOR

Top management must establish an AI policy that is appropriate to the organization, provides a framework for setting AI objectives, commits to satisfying applicable requirements, and commits to continual improvement of the AI management system. The policy must be documented, communicated within the organization, and available to interested parties as appropriate. It must also be consistent with the organization's other policies.

WHY IT EXISTS

The AI policy is the statement that gives every downstream AI standard its authority. The consistency requirement matters more here than in most standards, because AI policies are often written by a new function and end up contradicting existing positions on data use, procurement, or employment decisions, which leaves staff with two rules and no way to choose between them.

HOW TO AUDIT IT

1. Read the policy against each required element and record which are present, absent, or asserted without substance.
2. Confirm top management approval with an identifiable approver and date.
3. Test consistency against other organizational policies, particularly data protection, procurement, information security, and human resources. Look for contradictions on training data use, automated decision-making, and vendor selection.
4. Test communication by asking staff outside the AI function whether they know an AI policy exists and what it requires of them.
5. Check external availability where the organization claims it, and verify the mechanism works.
6. Confirm a defined review cycle and evidence the last review occurred on schedule.
7. Check whether the policy addresses use of third-party AI tools by staff, which is where most organizations have exposure and most policies are silent.

EVIDENCE TO COLLECT

- Approved AI policy with approver, date, and version
- Top management approval evidence
- Other organizational policies for consistency comparison
- Communication and acknowledgement records across the workforce
- External availability mechanism
- Review log with scheduled and actual dates

HOW TO DOCUMENT IT

Quote the specific policy sentence satisfying each required element with its section number. Record contradictions against other policies by quoting both, since the finding is the conflict and it cannot be evidenced by describing one document alone. Record acknowledgement coverage as a computed percentage against a complete population.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the AI policy contradicts the organization's data protection policy on the use of customer data for model training, leaving staff with conflicting instructions and no basis for choosing between them. Quote both. Where the gap is coverage: the policy is silent on staff use of external AI tools, which is the organization's largest current AI exposure.

5.3 Roles, responsibilities and authorities

WHAT THE CONTROL ASKS FOR

Top management must assign and communicate responsibilities and authorities for roles relevant to the AI management system. Two are named specifically: ensuring the AIMS conforms to the standard, and reporting on its performance to top management. Authority must accompany responsibility.

WHY IT EXISTS

AI systems cross functional boundaries in a way that leaves accountability ambiguous by default. A model built by data science, deployed by engineering, using data owned by a business unit, affecting people served by a fourth team, has four groups who each reasonably believe someone else owns the outcome. Explicit assignment is the only thing that resolves it.

HOW TO AUDIT IT

1. Obtain the responsibility matrix and confirm it names holders for the two specifically required duties.
2. Test AI system ownership specifically. For a sample of AI systems, ask who is accountable for the system's outputs and whether that person knows.
3. Test authority by asking role holders what they can do if a team declines to act on their finding.
4. Check that responsibilities are assigned across the full lifecycle, including post-deployment monitoring, which is the phase most commonly unowned.
5. Cross-check assignments against the current employee directory for departed or transferred staff.
6. Confirm deputies exist for critical roles and test one against a recent absence.

EVIDENCE TO COLLECT

- Roles and responsibilities matrix covering the AI lifecycle
- AI system inventory with named accountable owner per system
- Job descriptions or objectives containing AI governance duties
- Delegation or appointment records showing granted authority
- Current employee directory for reconciliation
- Deputy assignments for critical roles

HOW TO DOCUMENT IT

Record assigned versus understood responsibility in a two-column table by role, from your own interviews. Record ownership per AI system with confirmation from the named owner, since unconfirmed ownership is common and only detectable by asking. Capture authority test answers close to verbatim.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of AI systems in production have no accountable owner, and for a further number the recorded owner was unaware of the assignment. Post-deployment monitoring is unassigned across the portfolio. Give counts; the pattern is more compelling than any single instance.

6.1.1 Actions to address risks and opportunities: general

WHAT THE CONTROL ASKS FOR

When planning the AIMS, consider the context from 4.1 and the requirements from 4.2, then determine the risks and opportunities that must be addressed for the system to achieve its intended outcomes, to prevent or reduce undesired effects, and to achieve continual improvement. Plan the actions, integrate them into the system, and define how you will evaluate their effectiveness.

WHY IT EXISTS

These are risks to the management system itself, distinct from risks arising from AI systems. Loss of scarce AI governance skills, a reorganization that dissolves an oversight committee, or a budget cut can disable the system that manages every other AI risk. This is skipped more often in AI programmes than elsewhere because 6.1.2 and 6.1.4 absorb all the attention.

HOW TO AUDIT IT

1. Confirm risks to the AIMS itself are recorded distinctly from AI system risks. Look for entries on skills availability, resourcing, organizational change, and pace of regulatory development.
2. Verify inputs traceable from the context analysis and the interested party register.
3. Check that opportunities are addressed and not only risks, since their omission is a straightforward nonconformity.
4. For a sample, confirm a planned action exists, is integrated into an AIMS process rather than standing alone, and has a defined effectiveness measure.
5. Test effectiveness evaluation on an action completed at least six months ago.

EVIDENCE TO COLLECT

- Register covering AIMS-level risks and opportunities
- Traceability from context and interested party inputs
- Action plans with owners, dates, and integration points
- Effectiveness evaluation records for completed actions
- Planning session records

HOW TO DOCUMENT IT

State clearly whether AIMS-level risk is addressed separately from AI system risk, since conflating the two is the characteristic failure of this clause. Record traced inputs by name and the effectiveness evaluation method and conclusion for the sampled action.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization assesses risks arising from its AI systems but not risks to the programme that governs them, leaving predictable disruptions such as the loss of scarce specialist staff unplanned for. In a field with a thin talent market this argument carries unusual weight.

6.1.2 AI risk assessment

WHAT THE CONTROL ASKS FOR

Define and apply a repeatable AI risk assessment process. It must establish and maintain criteria for risk acceptance and for performing assessments, produce consistent and comparable results when repeated, identify risks that could affect the achievement of AI objectives, analyse consequence and likelihood, determine risk levels, and compare and prioritize them against the criteria.

WHY IT EXISTS

AI risk is harder to score than most because the consequences are frequently non-financial and diffuse, and the likelihood is often unknown rather than low. The repeatability requirement is therefore doing real work: without it, AI risk scores reflect the assessor's disposition toward the technology more than any property of the system.

HOW TO AUDIT IT

1. Obtain the methodology and confirm it defines both acceptance criteria and the criteria for performing assessments.
2. Test repeatability by independently applying the method to one recorded risk and comparing your score to the one on file.
3. Check that the consequence scale accommodates non-financial harm. Scales denominated only in currency cannot represent the harms AI systems typically cause and will systematically under-score them.
4. Confirm risk owners are named individuals with authority, not teams.
5. Check coverage across the AI system inventory and identify systems with no risk entry.
6. Verify the relationship between this clause and 6.1.4 is understood, since AI risk assessment and AI system impact assessment are distinct requirements and are frequently merged into one document that satisfies neither.
7. Confirm assessments were performed at the frequency the methodology requires.

EVIDENCE TO COLLECT

- Documented AI risk assessment methodology with acceptance criteria
- Current AI risk register with owners, analysis, and levels
- Consequence and likelihood scales
- Assessment session records with dates and participants
- AI system inventory for coverage comparison
- Prior register versions for consistency testing

HOW TO DOCUMENT IT

Document your independent re-scoring in full: the risk selected, each input applied, your derived score, the recorded score, and the variance. Record whether the consequence scale can express non-financial harm, quoting the scale, since this determines whether the whole register is capable of representing AI risk at all.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization's risk scale measures consequence only in financial terms, so harms to individuals from AI decisions score at or near zero and are never prioritized for treatment. This explains an entire pattern of under-treatment with a single structural cause, which is more useful than reporting the symptoms individually.

6.1.3 AI risk treatment

WHAT THE CONTROL ASKS FOR

Define and apply a process to select risk treatment options, determine the controls needed, compare those controls against the Annex A reference set to verify nothing necessary has been omitted, produce a **Statement of Applicability**, formulate a risk treatment plan, and obtain risk owner approval of the plan and of the residual risk. The Statement of Applicability lists every Annex A control with an applicability decision and a justification.

WHY IT EXISTS

This is where risk becomes action and where the SoA is produced, which is the document certification bodies examine most closely. The comparison against Annex A is a safety net: it forces a conscious rejection of each reference control rather than a silent omission.

HOW TO AUDIT IT

1. Obtain the SoA and confirm it covers all 38 Annex A controls with a decision and a substantive justification for each.
2. Test the direction of derivation. Confirm controls were selected from risks and then compared to Annex A, rather than Annex A being adopted wholesale and risks written afterwards to fit.
3. Sample exclusions and verify the stated reason against observed reality, paying particular attention to exclusions justified on the basis that the organization only uses rather than develops AI.
4. Check the treatment plan for owners, dates, and resources, and age overdue items against original dates.
5. Verify documented risk owner approval of both the plan and residual risk acceptance. Approval by the AI governance function on the owner's behalf does not satisfy the clause.

EVIDENCE TO COLLECT

- Statement of Applicability covering all 38 Annex A controls, approved and versioned
- AI risk treatment plan with owners, dates, and status
- Risk owner approval records for the plan and for residual risk
- Mapping from risks to selected controls
- Evidence of the Annex A comparison
- Aging report for overdue treatment items

HOW TO DOCUMENT IT

Report SoA completeness as counts: controls listed, controls with a stated justification, and controls whose justification is substantive. Present sampled exclusions in a table of control, stated reason, and verification result. Produce an aging analysis of open treatment items against original due dates.

EXECUTIVE SUMMARY TREATMENT

Suggested language: controls were excluded on the basis that the organization only uses AI rather than developing it, but the organization fine-tunes models on its own data, which is development. The exclusions are therefore unsupported and the associated risks untreated. Tie this back to the role determination finding at 4.1 if you raised one.

6.1.4 AI system impact assessment

WHAT THE CONTROL ASKS FOR

Define a process to assess the potential consequences for individuals, groups of individuals, and societies arising from the development, provision, or use of AI systems. This requirement has no counterpart in ISO/IEC 27001 and is one of the defining features of ISO/IEC 42001. It looks outward at who the system affects, whereas risk assessment looks inward at what threatens the organization's objectives.

WHY IT EXISTS

An AI system can operate exactly as designed, present no risk to the organization, and still cause serious harm to the people it makes decisions about. Conventional risk assessment will not surface that, because those people are not the organization and the harm is not the organization's loss. Impact assessment exists precisely to catch what risk assessment structurally cannot see.

HOW TO AUDIT IT

1. Obtain the impact assessment process and confirm it addresses all three named populations: individuals, groups, and societies. Processes covering only individual data protection impact are incomplete.
2. Confirm the process defines when an assessment is required, who performs it, who reviews it, and what happens when significant impact is identified.
3. Test the distinction from risk assessment. Ask what an impact assessment would surface that the risk assessment would not. If the answer is nothing, the two have been merged and the requirement is unmet.
4. Verify the process specifies the consequences of an adverse finding. An assessment process with no defined outcome cannot change any decision.
5. Check the timing requirement. Assessment must be capable of occurring before deployment, not only after.
6. Confirm the process addresses groups, which requires considering differential effects across populations rather than aggregate effects.
7. Check that reassessment is triggered by material change to the system, its data, or its deployment context.

EVIDENCE TO COLLECT

- Documented AI system impact assessment process
- Criteria determining when an assessment is required
- Defined roles for performing and reviewing assessments
- Defined outcomes and escalation paths for adverse findings
- Reassessment triggers
- Evidence the process was approved and communicated

HOW TO DOCUMENT IT

Record the answer to the question distinguishing impact assessment from risk assessment, close to verbatim, since it establishes whether the organization understands what this clause requires. Note whether all three populations are addressed, and treat societal impact separately, as it is the element most often absent entirely.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has no process for assessing how its AI systems affect the people subject to their decisions, having merged this requirement into its assessment of risks to itself. The two ask different questions and the second cannot answer the first. Where the process exists but has no defined consequence, state that an adverse finding would not change any deployment decision.

6.2 AI objectives and planning to achieve them

WHAT THE CONTROL ASKS FOR

Establish AI objectives at relevant functions and levels. Each must be consistent with the AI policy, measurable where practicable, take account of applicable requirements and the results of risk and impact assessment, be monitored, communicated, and updated as needed, and be documented. For each, plan what will be done, what resources are needed, who is responsible, when it will be complete, and how results will be evaluated.

WHY IT EXISTS

Objectives convert intent into something manageable. In AI programmes they matter particularly because the alternative is aspirational language about responsible AI that cannot be tested, cannot be resourced, and cannot fail. An objective that cannot fail is not an objective.

HOW TO AUDIT IT

1. Confirm objectives exist below the corporate level and are held by the functions that build and deploy AI, not only by the governance function.
2. Test measurability. For each sampled objective ask what number demonstrates success and where it comes from.
3. Verify linkage to risk assessment and impact assessment results.
4. Confirm all five planning elements are present per objective: actions, resources, responsibility, deadline, and evaluation method.
5. Check the most recent measurement date against the stated monitoring frequency.
6. Test communication by asking staff in the relevant function what their team's AI objective is.
7. Watch for objectives phrased as values rather than outcomes, such as ensuring AI is used ethically, which cannot be measured or missed.

EVIDENCE TO COLLECT

- Documented objectives at corporate and functional levels
- Objective plans covering all five required elements
- Most recent measurement results with dates
- Evidence of linkage to risk and impact assessment outputs
- Communication records per level
- Records of objectives being updated

HOW TO DOCUMENT IT

Use one table with a row per objective and a column per required element, marked present or absent. Quote objectives that are not measurable rather than describing them, since the wording is the evidence. Record the last measurement date beside the required frequency.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization's AI objectives are expressed as values rather than outcomes and cannot be measured, so there is no basis on which to state whether the AI governance programme is succeeding. Quote one or two. This is a common finding and the remediation is straightforward once the problem is visible.

6.3 Planning of changes

WHAT THE CONTROL ASKS FOR

When the organization determines that changes to the AI management system are needed, those changes must be carried out in a planned manner. This concerns changes to the management system itself: scope changes, methodology revisions, restructuring of the governance function, or changes in governance arrangements.

WHY IT EXISTS

Management systems degrade fastest during change, and AI governance functions are young, frequently reorganized, and dependent on a small number of people. A restructure that dissolves a review board, or a scope expansion made without revisiting impact assessment criteria, can disable large parts of the system without anyone noticing until the next audit.

HOW TO AUDIT IT

1. Identify AIMS changes since the last audit: scope, methodology, governance structure, tooling, and committee arrangements.
2. Request the plan produced before each change. Documentation created afterwards is a finding.
3. Assess whether the plan considered downstream effects on risk assessment, impact assessment, the SoA, competence requirements, and documented information.
4. Check communication to affected parties and the currency of dependent documents.
5. Distinguish this clause from 8.1, which covers operational changes, and confirm the organization understands which governs which.

EVIDENCE TO COLLECT

- Change plans dated before implementation
- Impact assessments covering dependent processes and documents
- Approval records for significant AIMS changes
- Updated downstream documents with revision dates
- Communication records

HOW TO DOCUMENT IT

List every AIMS change in the period with its date, and record whether a plan predated it. The date comparison is the evidence. Where downstream documents were not updated, name them and give the gap in days or note that no update occurred.

EXECUTIVE SUMMARY TREATMENT

Usually minor unless degradation resulted. Suggested language: the AI governance function was restructured without assessing the effect on existing oversight arrangements, and as a result AI system reviews went unperformed for a stated period. Give the duration.

7.1 Resources

WHAT THE CONTROL ASKS FOR

Determine and provide the resources needed to establish, implement, maintain, and continually improve the AI management system. Resources means people, budget, tooling, time, and access to specialist expertise.

WHY IT EXISTS

AI governance requires a combination of skills that is genuinely scarce: technical understanding of models, legal understanding of a fast-moving regulatory environment, and domain understanding of the affected context. Organizations routinely staff the function with one person holding one of the three. Most downstream failures trace back here.

HOW TO AUDIT IT

1. Establish what the organization determined it needs, looking for a documented resourcing analysis rather than a headcount that accumulated.
2. Compare determined need against actual provision across at least two cycles, covering headcount, budget, and tooling.
3. Assess the skill mix rather than only the count, since three people with the same background do not cover the required range.
4. Correlate shortfalls with other findings and link them explicitly.
5. Check use of external expertise where internal capability is absent, particularly legal and domain expertise.
6. Ask the AIMS owner what is currently not being done, and compare their answer to your own findings.

EVIDENCE TO COLLECT

- Resourcing or capacity analysis for AI governance
- Budget requests and approvals across cycles
- Current headcount against approved and against assessed need
- Skills profile of the function
- Contracts for external specialist support
- Backlog or work queue data

HOW TO DOCUMENT IT

Present requested versus approved resource by cycle. Cross-reference every downstream finding you believe results from the shortfall, by finding number. Record the skill mix, since a resourcing finding based on capability gaps is more precise and harder to dismiss than one based on headcount.

EXECUTIVE SUMMARY TREATMENT

Suggested language: AI governance is staffed below the level the organization itself assessed as necessary, and the function holds no legal or domain expertise, which is the direct cause of a stated number of other findings in this report. List them by number.

7.2 Competence

WHAT THE CONTROL ASKS FOR

Determine the competence needed by people whose work affects AI performance, ensure they are competent on the basis of education, training, or experience, act where they are not, and retain documented evidence of competence. Competence means demonstrated ability to do the specific job.

WHY IT EXISTS

AI work fails invisibly. A poorly constructed evaluation, an unrepresentative training set, or a misread fairness metric produces a system that looks correct and is not. Unlike most domains, the person doing the work may not be able to tell. Competence must therefore be verified rather than assumed from a job title.

HOW TO AUDIT IT

1. Obtain competence requirements per AI-relevant role. If none exist the clause fails at the first requirement.
2. Sample individuals across roles and compare held evidence against the defined requirement.
3. Check that competence is verified rather than assumed. Attendance records prove attendance; look for assessment, certification, or documented experience evaluation.
4. Include the people reviewing and approving AI systems, not just those building them. A reviewer who cannot evaluate what they approve is the more consequential gap.
5. Include contractors and third parties performing AI-relevant work.
6. Check action taken where gaps were found and verify closure.
7. Confirm competence requirements reflect the pace of change in the field, and check when they were last reviewed.

EVIDENCE TO COLLECT

- Competence requirements per AI-relevant role
- Individual competence records: qualifications, certifications, assessments, experience evaluations
- Competence evidence for reviewers and approvers
- Contractor and third-party competence evidence
- Gap remediation records with closure evidence
- Training plan and completion data

HOW TO DOCUMENT IT

Build a sample table of person, role, required competence, evidence held, and conclusion. Record reviewers and approvers separately from builders, because that is usually where the gap is and a blended sample conceals it. State the sample size against population and the selection method.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the people approving the organization's AI systems for deployment have no verified competence to evaluate them, so approval is a procedural step rather than a technical review. This is more consequential than a training gap among builders and is frequently overlooked.

7.3 Awareness

WHAT THE CONTROL ASKS FOR

People doing work under the organization's control must be aware of the AI policy, their contribution to the effectiveness of the AI management system including the benefits of improved performance, and the implications of not conforming to its requirements. The population includes contractors and temporary staff.

WHY IT EXISTS

AI capability is now available to every employee through ordinary software, which means every employee is a potential point of AI-related exposure regardless of their role. Awareness is the only control that scales to that population. The requirement to communicate the consequences of nonconformity matters because AI rules are frequently perceived as advisory.

HOW TO AUDIT IT

1. Confirm the content covers all three required elements, since programmes commonly cover AI tool usage while never mentioning the policy or the consequences of noncompliance.
2. Verify the population includes contractors and temporary staff by reconciling completion records to a complete population list.
3. Test effect rather than delivery by asking staff to describe what they may and may not do with AI tools.
4. Check timing for new starters relative to their access to AI-capable tooling.
5. Verify content currency. AI awareness material more than a year old will not reflect the tools staff are currently using.
6. Check whether awareness distinguishes between approved and unapproved AI tools and states how to tell.

EVIDENCE TO COLLECT

- Awareness content covering the three required elements
- Completion records reconciled to a complete population including contractors
- New starter onboarding records with dates
- Content revision history
- Knowledge assessment results if used
- List of approved AI tools communicated to staff

HOW TO DOCUMENT IT

Record the population reconciliation as total workforce, number with completion records, and the difference. Record staff answers to the scenario questions, since these measure awareness where completion statistics measure attendance. Note the content revision date against the current tool landscape.

EXECUTIVE SUMMARY TREATMENT

Suggested language: staff have not been told which AI tools they may use or what they may put into them, and a stated number of people with access to company information have no record of any AI awareness training. Give the number and the contractor proportion.

7.4 Communication

WHAT THE CONTROL ASKS FOR

Determine the internal and external communications relevant to the AI management system, including what will be communicated, when, with whom, and how. This is a planning requirement: the approach must be decided deliberately rather than emerging ad hoc.

WHY IT EXISTS

AI communication carries obligations that other domains do not. Disclosing that a decision was made with AI assistance, explaining an outcome to an affected person, and notifying a regulator of a serious incident all have timing and content requirements. Deciding these in advance is the difference between a managed disclosure and an improvised one.

HOW TO AUDIT IT

1. Obtain the communication plan and confirm it addresses what, when, with whom, and how.
2. Check that external communication covers regulators, customers, and affected individuals, not only internal channels.
3. Verify that disclosure obligations are reflected, including telling people when AI is involved in decisions affecting them.
4. Check whether AI incident notification timelines are recorded, since these differ from information security breach timelines.
5. Test against a real event. Compare actual communication during a recent AI incident or significant change to the plan.
6. Confirm named roles are currently filled and contact routes verified.

EVIDENCE TO COLLECT

- Communication plan covering internal and external audiences
- Disclosure procedures for AI involvement in decisions
- AI incident communication procedures with timelines
- Regulatory notification requirements mapped to the plan
- Records of actual communications during a recent event
- Contact lists with verification dates

HOW TO DOCUMENT IT

Present plan against actual for the tested event as a timeline with variances in hours or days. Record whether disclosure of AI involvement in decisions is addressed at all, since its absence is common and increasingly consequential under emerging regulation.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has no defined approach for telling people when an AI system was involved in a decision affecting them, which is an obligation under regulation applicable to it. Name the regulation and the affected decision types.

7.5.1 Documented information: general

WHAT THE CONTROL ASKS FOR

The AIMS must include the documented information the standard requires plus whatever the organization determines is necessary for its effectiveness. **Documented information** covers both documents, which state what should happen, and records, which evidence what did happen.

WHY IT EXISTS

AI systems are unusually dependent on documentation because their behaviour cannot be inferred from inspection. Nobody can determine from a deployed model what data it was trained on, what it was evaluated against, or what its known limitations are. If that is not written down, it is unrecoverable.

HOW TO AUDIT IT

1. Build a checklist of every explicitly required documented information item in the standard and verify each exists.
2. Ask how the organization determined what additional documentation is necessary and whether that determination is recorded.
3. Test sufficiency in the other direction by finding an AI system whose development is undocumented and assessing whether anyone could now reconstruct its training data, evaluation results, or known limitations.
4. Check that documents match practice, and where they differ determine which is wrong.
5. Confirm retention periods are defined and observed, noting that AI documentation may need to outlive the system for accountability purposes.

EVIDENCE TO COLLECT

- Master document register for the AIMS
- The specific documented information items the standard requires
- Rationale for additional documentation determined necessary
- Retention schedule covering AI system documentation
- Sample of records evidencing process performance

HOW TO DOCUMENT IT

Include the required-items checklist in full with the location of each or a note that it is absent; this is reusable and makes completeness self-evident. For the reconstruction test, name the system and state specifically what can no longer be established about it.

EXECUTIVE SUMMARY TREATMENT

Suggested language: for a stated number of AI systems in production, the organization cannot establish what data they were trained on or what they were tested against, so it cannot answer questions from customers, regulators, or affected individuals about how they behave. Give the count.

7.5.2 Creating and updating documented information

WHAT THE CONTROL ASKS FOR

When creating or updating documented information, ensure appropriate identification and description such as title, date, author, and reference; appropriate format and media; and appropriate review and approval for suitability and adequacy.

WHY IT EXISTS

Unidentifiable documents cannot be relied on. In AI contexts this bites hardest on model documentation, where a specification without a version cannot be matched to the model actually running, which makes it worthless for the accountability purpose it was created for.

HOW TO AUDIT IT

1. Sample AIMS documents and check each for title, identifier, version, date, author, and approver.
2. Verify the approver had authority to approve, and look for self-approval by the author.
3. Check that AI system documentation is versioned in a way that ties it to a specific model version, since this is the linkage that makes it useful.
4. Compare the repository copy against copies circulating elsewhere and look for divergent versions.
5. Confirm review addressed suitability and adequacy by asking the approver what they questioned or changed.

EVIDENCE TO COLLECT

- Sampled documents with visible metadata
- Approval records showing approver identity and date
- Delegation of authority defining approval rights
- Model version to documentation version linkage evidence
- Copies found in secondary locations

HOW TO DOCUMENT IT

Use a sample table with a row per document and a column per required attribute. Record specifically whether model documentation identifies the model version it describes, since this single attribute determines whether the documentation is usable.

EXECUTIVE SUMMARY TREATMENT

Rarely escalated alone. Where it matters: AI system documentation cannot be matched to the model versions actually running in production, so the organization cannot state what any deployed system was designed or tested to do.

7.5.3 Control of documented information

WHAT THE CONTROL ASKS FOR

Documented information must be available and suitable for use where and when needed, and adequately protected from loss of confidentiality, improper use, or loss of integrity. Address distribution, access, retrieval, use, storage, preservation, version control, retention, and disposition, including documents of external origin.

WHY IT EXISTS

AIMS documentation is itself sensitive: model specifications, evaluation results, known failure modes, and training data descriptions are commercially valuable and useful to anyone seeking to manipulate the system. Organizations apply strict controls to model weights and leave the documentation describing their weaknesses broadly accessible.

HOW TO AUDIT IT

1. Test access controls on the AIMS repository and check whether sensitive items such as evaluation results and known limitations are more tightly controlled than general policies.
2. Test retrieval by asking someone to locate a specific current document and timing it.
3. Verify version control prevents superseded documents from circulating.
4. Confirm retention and disposition are applied, including whether AI documentation is retained long enough to support later accountability.
5. Check control of external documents such as standards, regulatory guidance, and supplier model cards, and confirm the versions relied on are current.
6. Confirm backup covers the repository.

EVIDENCE TO COLLECT

- Access control lists for the AIMS repository
- Version control configuration and history
- Retention schedule and disposal evidence
- Register of external documents with currency check dates
- Backup records covering the repository
- Retrieval test results

HOW TO DOCUMENT IT

Record the access review as who has access against who needs it, with the excess count. For external documents, list each with the version held against the current published version, since organizations frequently operate against superseded regulatory guidance in a fast-moving field.

EXECUTIVE SUMMARY TREATMENT

Suggested language: documentation describing the known failure modes and limitations of the organization's AI systems is accessible to a far wider group than needs it. If external currency is the issue, state that the organization is operating against superseded regulatory guidance and name it.

8.1 Operational planning and control

WHAT THE CONTROL ASKS FOR

Plan, implement, and control the processes needed to meet AIMS requirements and to carry out the actions determined in Clause 6. Keep documented information sufficient to have confidence the processes were carried out as planned. Control planned changes, review the consequences of unintended changes and act to mitigate adverse effects, and ensure externally provided processes relevant to the AIMS are controlled.

WHY IT EXISTS

This is where planning becomes operation. The unintended change requirement is particularly significant for AI, because AI systems change without anyone changing them: model behaviour drifts as the input distribution shifts, and vendor-hosted models are updated by the vendor on their schedule, not yours.

HOW TO AUDIT IT

1. Confirm operational processes exist for the AI governance activities the organization committed to, and that they run at the stated frequency.
2. Test that records provide confidence processes ran as planned.
3. Examine unintended change specifically. Ask how the organization would know if a vendor updated a model it depends on, and check whether that has happened in the period.
4. Check drift detection for models in production, and confirm someone acts on it.
5. Examine externally provided processes. For each outsourced AI-relevant activity, verify a control mechanism exists and is exercised.
6. Look for AI systems operating outside the defined processes entirely, using procurement or expense records rather than the AI inventory.

EVIDENCE TO COLLECT

- Operational procedures with stated frequencies
- Records evidencing execution
- Vendor model change notification arrangements and records of actual changes
- Drift monitoring configuration and output
- Contracts for outsourced AI-relevant processes
- Procurement or expense records used to identify unregistered AI systems

HOW TO DOCUMENT IT

Record the answer to the vendor model change question and any actual instance in the period, including whether the organization detected it or learned of it afterwards. This is the clearest test of whether operational control extends to systems the organization does not host.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization would not know if a vendor changed a model its decisions depend on, and a named vendor updated its model during the period without the organization detecting it or reassessing the system. This is a control gap executives grasp immediately because it is a supplier control question in familiar terms.

8.2 AI risk assessment

WHAT THE CONTROL ASKS FOR

Perform AI risk assessments at planned intervals and when significant changes are proposed or occur, and retain documented information about the results. Clause 6.1.2 requires the process to exist; this clause requires it to be run, on schedule and on trigger.

WHY IT EXISTS

AI risk changes faster than most, because the systems change, the data changes, the regulatory position changes, and the threat landscape changes independently of each other. Scheduled assessment alone will always lag. The trigger requirement is what keeps assessment attached to reality.

HOW TO AUDIT IT

1. Compare required assessment frequency to actual performance dates.
2. Identify significant changes in the period independently, using change records, project lists, and vendor communications, then check whether each triggered an assessment.
3. Confirm the definition of significant change is documented, since without it the trigger cannot be applied consistently.
4. Verify results are retained in enough detail to reconstruct the conclusion.
5. Compare successive assessments for genuine reassessment rather than a copied register with a new date.
6. Check that model retraining and material data changes are treated as significant changes, since these alter system behaviour and are frequently not recognized as triggers.

EVIDENCE TO COLLECT

- Assessment schedule and records of actual performance
- Definition of significant change
- Independently compiled list of significant changes in the period
- Change-triggered assessment records
- Successive risk register versions
- Model retraining records

HOW TO DOCUMENT IT

Present significant changes you identified against whether an assessment followed each. Compiling that list independently rather than accepting the organization's is what gives this test its value; record your sources. Note specifically whether retraining events triggered reassessment.

EXECUTIVE SUMMARY TREATMENT

Suggested language: models were retrained on new data during the period without any reassessment of the risks that retraining introduced, so the risk position on record describes systems that no longer exist in that form. Give the number of retraining events and how many triggered assessment.

8.3 AI risk treatment

WHAT THE CONTROL ASKS FOR

Implement the AI risk treatment plan and retain documented information about the results. The plan agreed under 6.1.3 must be executed and there must be records demonstrating it.

WHY IT EXISTS

The gap between agreed and completed remediation is where residual risk actually lives. AI programmes are particularly prone to it because treatment frequently depends on engineering capacity that is fully committed to delivery, so security and governance work is deferred indefinitely without a formal decision to defer it.

HOW TO AUDIT IT

1. Sample treatment plan items and verify claimed completion against independent evidence rather than the status field.
2. Age open items against original committed dates, not revised dates, and record how many times each date moved.
3. For completed items, confirm the treatment reduced the risk as intended and that the register was updated to the new residual level.
4. Identify items closed by late risk acceptance and confirm the acceptance was approved by the risk owner.
5. Check whether non-completion concentrates in items requiring engineering capacity, and link to Clause 7.1 if so.

EVIDENCE TO COLLECT

- Risk treatment plan with original and current target dates
- Independent completion evidence for sampled items
- Updated risk register showing revised residual risk
- Records of date revisions with justification
- Late risk acceptance approvals

HOW TO DOCUMENT IT

Produce an aging table of item, original due date, current due date, revision count, and days overdue against the original. The revision count column reveals systemic slippage that a status field conceals. Name the independent evidence inspected for each sampled completion.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of agreed AI risk remediations are past their original committed dates, the oldest by a stated period, and the dates have been revised an average of a stated number of times. The revision count is the figure that distinguishes slippage from a one-off delay.

8.4 AI system impact assessment

WHAT THE CONTROL ASKS FOR

Perform AI system impact assessments at planned intervals and when significant changes occur, and retain documented information about the results. This is the execution counterpart to 6.1.4, and like that clause it has no equivalent in ISO/IEC 27001.

WHY IT EXISTS

An impact assessment process that is never run protects nobody. Assessments must also occur early enough to change something: an assessment completed after deployment can identify harm but cannot prevent it. Timing is therefore the substance of this clause rather than an administrative detail.

HOW TO AUDIT IT

1. Compare the AI system inventory against completed impact assessments and identify systems with none.
2. Check timing. Compare assessment completion dates to deployment dates for a sample. Assessments completed after deployment did not inform the deployment decision.
3. Verify assessments address all three populations: individuals, groups, and societies. Societal impact is the element most commonly missing.
4. Assess depth. Look for identified potential harms with reasoning, not a completed template with affirmative answers throughout.
5. Check what happened where an assessment identified significant potential impact. If nothing changed, the process has no effect.
6. Verify reassessment occurred where systems, data, or deployment contexts materially changed.
7. Check whether assessments consider differential effects across groups rather than aggregate effects only.

EVIDENCE TO COLLECT

- Completed impact assessments with dates
- AI system inventory with deployment dates for comparison
- Evidence of actions taken in response to assessment findings
- Reassessment records following material change
- Consultation or research evidence supporting the assessments
- Records of any system modified or not deployed following assessment

HOW TO DOCUMENT IT

Present assessment date against deployment date for every sampled system, with the variance in days. Negative variances, where assessment followed deployment, are the core finding and the table makes them undeniable. Record separately whether any assessment ever resulted in a change to a system.

EXECUTIVE SUMMARY TREATMENT

Suggested language: impact assessments for a stated number of AI systems were completed after those systems were already in production, and no assessment has resulted in a change to any system. The process therefore documents impacts rather than preventing them. Give the count and the average delay in days.

9.1 Monitoring, measurement, analysis and evaluation

WHAT THE CONTROL ASKS FOR

Determine what needs monitoring and measuring, the methods used, when it is performed and by whom, and when results are analysed and evaluated and by whom. Methods must produce valid results, meaning comparable and reproducible. Retain documented information as evidence and evaluate both AI performance and AIMS effectiveness.

WHY IT EXISTS

AI systems degrade in ways that are invisible without measurement. A model whose accuracy has fallen produces confident outputs at exactly the same rate as one that is working. Monitoring is therefore not a governance overhead in AI; it is the only mechanism by which failure becomes visible at all.

HOW TO AUDIT IT

1. Obtain the measurement plan and confirm it specifies what, how, when, and by whom for both AI performance and AIMS effectiveness.
2. Check that production model performance is monitored, not only pre-deployment evaluation results. Systems evaluated once at launch and never since are common.
3. Assess validity. Ask whether repeating a measurement would produce the same result and whether it measures outcome or activity.
4. Check whether monitoring covers the properties that matter beyond accuracy: differential performance across groups, drift, and failure modes identified in impact assessment.
5. Verify measurement occurs at the stated frequency by comparing planned to actual dates.
6. Trace a measurement result to a decision. Metrics that never change anything indicate evaluation is not functioning.
7. Confirm someone is named to analyse results and that the analysis reaches a conclusion rather than presenting numbers.

EVIDENCE TO COLLECT

- Measurement plan with metrics, methods, frequencies, and owners
- Production monitoring results across multiple periods
- Pre-deployment evaluation results for comparison
- Differential performance measurement across groups
- Analysis records with conclusions
- Evidence of decisions driven by measurement

HOW TO DOCUMENT IT

Record, for each production AI system, the date of its last performance measurement against the required frequency. Blank or stale entries are the finding and they are usually numerous. Recalculate one metric independently and record whether your figure matched.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of AI systems in production have not had their performance measured since deployment, so the organization would not know if they had stopped working correctly. This is the most important AI-specific finding available in this clause because the failure mode is silent.

9.2 Internal audit

WHAT THE CONTROL ASKS FOR

Conduct internal audits at planned intervals to determine whether the AIMS conforms to the organization's own requirements and to the standard, and is effectively implemented and maintained. Plan and maintain an audit programme covering frequency, methods, responsibilities, planning requirements, and reporting. Define criteria and scope per audit, select auditors ensuring objectivity and impartiality, report results to relevant management, and retain documented information.

WHY IT EXISTS

Internal audit is the organization's own detection capability for management system failure. For AI it faces an additional difficulty: auditing an AI system requires technical competence that general internal auditors usually do not have, which means audits are frequently performed at a level that cannot find anything substantive.

HOW TO AUDIT IT

1. Obtain the audit programme and confirm it covers the whole AIMS across a defined cycle, including Annex A controls and all management system clauses.
2. Verify the programme is risk-based rather than a fixed rotation.
3. Test auditor independence per audit, confirming no auditor audited their own work or reported to the manager of the audited area.
4. Assess auditor competence for AI subject matter specifically, linking to Clause 7.2. This is the distinctive weakness in AI internal audit.
5. Compare planned to completed audits and examine deferrals.
6. Review a sample of reports for depth. Reports with no findings across an entire AIMS usually indicate shallow work.
7. Confirm results reached relevant management with dates.

EVIDENCE TO COLLECT

- Internal audit programme covering the full cycle
- Risk-based rationale for the programme
- Individual audit plans with criteria and scope
- Auditor independence declarations and reporting lines
- Auditor competence records covering AI subject matter
- Completed reports with findings
- Evidence of delivery to management

HOW TO DOCUMENT IT

Produce a coverage map of every AIMS clause and Annex A category against the date last internally audited. Record auditor competence for AI subject matter separately from general audit competence, since the two are routinely conflated and only the first determines whether AI findings were findable.

EXECUTIVE SUMMARY TREATMENT

Suggested language: internal audits of the AI management system are performed by auditors with no competence in the subject matter, and have produced no findings across the period. The combination is the point: the absence of findings reflects the audit rather than the system.

9.3 Management review

WHAT THE CONTROL ASKS FOR

Top management must review the AIMS at planned intervals for continuing suitability, adequacy, and effectiveness. The review must consider a defined set of inputs including the status of prior actions, changes in internal and external issues, changes in interested party needs, performance information covering nonconformities, monitoring results, audit results and objective achievement, feedback from interested parties, risk assessment and treatment status, impact assessment results, and opportunities for improvement. Outputs must include decisions on improvement and any changes needed.

WHY IT EXISTS

This is the governance loop that closes the system, and the point at which evidence reaches the people with authority to act. For AI it carries additional weight because most of the decisions that matter, such as whether to keep operating a system that is causing harm, can only be made at this level.

HOW TO AUDIT IT

1. Confirm reviews occurred at the planned frequency by comparing planned to actual dates.
2. Check attendance. Top management must attend; a review conducted by the AI function and circulated afterwards does not satisfy the clause.
3. Work through every required input item by item against the review pack and minutes. Missing inputs are straightforward nonconformities and impact assessment results are the most commonly absent.
4. Test outputs for decisions with owners and dates rather than observations.
5. Trace prior actions forward into the current review with status.
6. Confirm an explicit conclusion on suitability, adequacy, and effectiveness.

EVIDENCE TO COLLECT

- Review schedule and actual meeting dates
- Attendance records identifying roles
- Review packs or input documents
- Minutes recording discussion, decisions, owners, and dates
- Action tracker showing prior actions and closure
- Explicit conclusions on suitability, adequacy, and effectiveness

HOW TO DOCUMENT IT

Use a checklist table of every required input against present or absent with the page reference in the pack where present. This is the most efficient test in the clause. Record outputs separately, distinguishing decisions from observations.

EXECUTIVE SUMMARY TREATMENT

Suggested language: management reviews of the AI programme do not consider the results of impact assessments, so leadership is approving a system without being shown how it affects the people subject to its decisions. Name the missing inputs.

10.1 Continual improvement

WHAT THE CONTROL ASKS FOR

Continually improve the suitability, adequacy, and effectiveness of the AI management system. No method is prescribed. It is tested by looking for evidence that the system is deliberately improving, driven by the outputs of measurement, audit, review, incidents, and impact assessment.

WHY IT EXISTS

The AI field, its regulation, and its risks are all moving quickly. A management system that stands still falls behind without anyone deciding to let it. Continual improvement is the requirement that makes stagnation a nonconformity rather than a drift nobody owns.

HOW TO AUDIT IT

1. Ask for the improvements made in the period and the trigger for each. Improvements with no traceable trigger are usually projects relabelled.
2. Confirm improvement is driven by the system's own outputs rather than by external pressure alone.
3. Distinguish improvement from correction. Fixing a broken control is corrective action under 10.2.
4. Assess whether improvements were evaluated for effect.
5. Look at trend data across periods and challenge flat or worsening trends alongside claimed improvement.
6. Check whether the system has adapted to regulatory developments in the period, since failure to do so is the characteristic stagnation in this field.

EVIDENCE TO COLLECT

- Improvement register with triggers and outcomes
- Evidence linking improvements to audit, measurement, or review outputs
- Before and after measurement for sampled improvements
- Multi-period trend data
- Records of adaptation to regulatory change

HOW TO DOCUMENT IT

Record improvements in a table of improvement, trigger, date, and measured effect. The trigger column separates genuine continual improvement from ordinary project work. Note specifically whether the system has responded to regulatory developments during the period.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the AI management system has not changed in response to significant regulatory developments during the period, and the changes described as improvements were not evaluated for effect. Name the developments.

10.2 Nonconformity and corrective action

WHAT THE CONTROL ASKS FOR

When a **nonconformity** occurs, react to control and correct it and deal with the consequences. Then evaluate whether action is needed to eliminate the cause so it does not recur, by reviewing the nonconformity, determining its causes, and checking whether similar ones exist or could occur. Implement any action needed, review its effectiveness, and change the AIMS if necessary. Retain documented information on the nature of the nonconformity, the actions taken, and the results.

WHY IT EXISTS

The distinction between correction and corrective action is the whole point. Correction fixes the instance; corrective action fixes the cause. In AI this matters particularly because the same underlying cause, such as an unrepresentative data pipeline, will surface repeatedly across different systems and appear each time as a new and unrelated problem.

HOW TO AUDIT IT

1. Confirm nonconformities from all sources feed one process: internal audit, external audit, incidents, monitoring, and self-identification.
2. For a sample, verify both correction and cause analysis occurred, and assess whether the recorded cause is a cause or a restatement of the symptom.
3. Check the similar-occurrence review. Confirm the organization asked where else the same weakness exists, particularly across other AI systems sharing data sources or pipelines.
4. Verify effectiveness review occurred far enough after implementation to be meaningful.
5. Analyse recurrence across periods. Repeating nonconformities indicate cause analysis is not working regardless of closure rates.
6. Confirm retained records cover nature, actions, and results.

EVIDENCE TO COLLECT

- Nonconformity and corrective action register covering all sources
- Root cause analysis records
- Similar-occurrence review results across the AI portfolio
- Effectiveness review records with dates after implementation
- Multi-period recurrence data
- Closure approvals with supporting evidence

HOW TO DOCUMENT IT

For each sampled item record the stated cause and your assessment of whether it is a cause or a symptom, with reasoning. Present recurrence as counts by type across periods. Record the interval between implementation and effectiveness review, since same-day reviews are not meaningful.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the same underlying failure has recurred across a stated number of AI systems because the organization corrects each instance without addressing the shared cause. Naming the shared cause, such as a common data pipeline, converts several apparently separate problems into one fixable one.

Annex A.2: Policies Related to AI

Three controls covering the AI policy itself: that it exists, that it does not contradict the organization's other policies, and that it is reviewed. Short, and usually treated as the easy part of Annex A.

It is not. The recurring failure here is a policy of principles rather than requirements. A document stating that the organization will use AI responsibly and ethically cannot be complied with, cannot be breached, and cannot be audited. When you read the policy, the test is simple: can you identify a specific action it permits and a specific action it prohibits? If not, everything built on top of it is resting on nothing.

The alignment control (A.2.3) produces more findings than its length suggests. AI policies are written by new functions and routinely contradict existing positions on training data, automated decisions, and vendor thresholds.

Quick reference: A.2 Policies

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [cyb](#) or [ai](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
A.2.2	AI policy	Approved AI policy with version, date, and approver
A.2.3	Alignment with other organizational policies	List of interacting policies identified by the organization
A.2.4	Review of the AI policy	Review schedule with defined interval

A.2.2 AI policy

WHAT THE CONTROL ASKS FOR

Document an AI policy, have it approved by management, and make it available to the people it applies to. The policy sets the organization's position on developing, providing, and using AI systems, and it is the document from which every subordinate AI standard draws its authority.

WHY IT EXISTS

Without a policy, AI requirements are one function's preference and can be declined by anyone under delivery pressure. The policy is also the first document a customer, regulator, or auditor asks for, and its content is taken as the organization's formal position whether or not practice matches it.

HOW TO AUDIT IT

1. Obtain the policy and assess whether it takes actual positions. Policies asserting that the organization will use AI responsibly, without saying what that permits or prohibits, cannot be complied with or breached.
2. Confirm documented management approval with an identifiable approver and date.
3. Check availability to the people it applies to, and test by asking staff to find it.
4. Verify the policy addresses the organization's actual AI activity, including the roles determined under Clause 4.1.
5. Check whether it covers staff use of third-party AI tools, which is most organizations' largest exposure and most policies' largest gap.
6. Test two specific policy requirements operationally and compare stated requirement to observed practice.

EVIDENCE TO COLLECT

- Approved AI policy with version, date, and approver
- Management approval evidence
- Publication and communication records
- Acknowledgement records against a complete population
- Evidence of operational compliance with two sampled requirements

HOW TO DOCUMENT IT

Quote the specific policy provisions you tested operationally alongside what you observed. Record whether the policy contains testable requirements at all, since a policy of aspirations produces no findable nonconformities and that is itself the finding.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the AI policy states principles but no requirements, so there is nothing staff can be held to and nothing an auditor can test. If coverage is the gap, state that the policy does not address staff use of external AI tools.

A.2.3 Alignment with other organizational policies

WHAT THE CONTROL ASKS FOR

Identify where the AI policy interacts with other organizational policies and make sure they are consistent. AI touches data protection, information security, procurement, human resources, and quality, and each of those already has positions that may conflict with new AI requirements.

WHY IT EXISTS

Contradictory policies are worse than a missing one, because staff facing two rules will follow whichever is more convenient and can justify it afterwards. The conflicts arise naturally: AI policies are usually written by a new function without renegotiating the positions already held elsewhere.

HOW TO AUDIT IT

1. Identify the policies that interact with AI and confirm the organization has identified the same set.
2. Read them against each other looking for conflict on the recurring flashpoints: use of customer or employee data for training, automated decision-making about people, vendor assessment thresholds, and retention.
3. Check whether a reconciliation was performed and documented, or whether alignment is merely asserted.
4. Ask staff subject to both which they would follow in a conflict, since their answer reveals which policy has practical force.
5. Confirm a mechanism exists to maintain alignment when any of the policies change.

EVIDENCE TO COLLECT

- List of interacting policies identified by the organization
- Reconciliation or alignment analysis
- The interacting policies themselves for comparison
- Change control arrangements linking the policy set
- Interview notes on conflict resolution in practice

HOW TO DOCUMENT IT

Where you find a conflict, quote both provisions with their document and section references. The finding is the contradiction and it cannot be evidenced by describing one side. Record which policy staff said they would follow.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the AI policy and the data protection policy give conflicting instructions on using customer data to train models, and staff report following the AI policy because it is more permissive. Quote both. This is a governance failure with immediate regulatory consequence.

A.2.4 Review of the AI policy

WHAT THE CONTROL ASKS FOR

Review the AI policy at planned intervals, and additionally when significant changes occur, to confirm it remains suitable, adequate, and effective.

WHY IT EXISTS

No policy ages faster. Regulation, model capability, and the tools available to staff all change within months. A policy written before the organization's current AI tooling existed will contain requirements nobody can meet and omit the situations that actually arise, which teaches staff that the policy is not to be taken seriously.

HOW TO AUDIT IT

1. Confirm a defined review interval and compare it to the actual review dates.
2. Check whether reviews were triggered by significant change as well as by schedule, and identify changes in the period that should have triggered one.
3. Assess review substance. A review that changed nothing across a period of significant regulatory and technological change warrants challenge.
4. Verify reviews considered suitability, adequacy, and effectiveness rather than only checking for typographical currency.
5. Confirm review outcomes were approved and communicated.

EVIDENCE TO COLLECT

- Review schedule with defined interval
- Review records with dates, participants, and outcomes
- Policy revision history showing what changed
- Trigger events in the period for comparison
- Approval and communication records for revisions

HOW TO DOCUMENT IT

Compare policy revision dates against the significant regulatory and technological developments of the period, listed by date. That comparison evidences staleness far better than reporting the interval between reviews.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the AI policy has not been reviewed since a named regulatory development that directly affects the organization, and predates the AI tooling now in general use across the workforce. Give both dates.

Annex A.3: Internal Organization

Two controls: who is responsible for AI, and how people raise concerns about it.

AI systems have more distinct stakeholders than most technology, and responsibility diffuses across them by default. Whoever supplied the data, whoever built the model, whoever deployed it, and whoever owns the decision it influences can each reasonably believe another party owns the outcome. Post-deployment monitoring is the duty that most reliably ends up owned by nobody, and it is the duty whose absence causes the most damage.

Test the concern-reporting control by volume rather than by design. A mechanism that exists and receives nothing is telling you something.

Quick reference: A.3 Organization

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [cyb](#) or [ai](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
A.3.2	AI roles and responsibilities	AI roles and responsibilities matrix covering the lifecycle
A.3.3	Reporting of concerns	Reporting mechanism description and access routes

A.3.2 AI roles and responsibilities

WHAT THE CONTROL ASKS FOR

Define and allocate the roles and responsibilities for AI within the organization. This is the operational counterpart to Clause 5.3 and covers the whole population involved with AI systems, not only the governance function.

WHY IT EXISTS

AI systems have more distinct stakeholders than most technology: whoever supplies the data, whoever builds the model, whoever deploys it, whoever operates it, and whoever owns the decision it influences. Left undefined, each reasonably assumes another owns the outcome, and post-deployment monitoring in particular ends up owned by nobody.

HOW TO AUDIT IT

1. Obtain the allocation and confirm it covers the full lifecycle including data sourcing, development, deployment, operation, monitoring, and retirement.
2. For a sample of AI systems, identify the named owner and confirm with that person that they know.
3. Test the duties most often unassigned: performance monitoring, drift detection, periodic revalidation, and handling of complaints about system outputs.
4. Check that responsibilities are reflected somewhere with force, such as objectives or job descriptions, rather than only in a matrix.
5. Cross-check assignments against the current employee directory.
6. Confirm deputies exist for critical roles.

EVIDENCE TO COLLECT

- AI roles and responsibilities matrix covering the lifecycle
- AI system inventory with named owner per system
- Job descriptions or objectives containing AI duties
- Current employee directory for reconciliation
- Evidence of performance for the sampled unassigned duties
- Deputy assignments

HOW TO DOCUMENT IT

Use a table of duty, documented owner, owner confirmed, and evidence of recent performance. That three-way test separates paper allocation from working allocation. List every duty with no identifiable owner, since those are usually the ones already failing silently.

EXECUTIVE SUMMARY TREATMENT

Suggested language: post-deployment monitoring of AI systems is unassigned across the portfolio, and consequently a stated number of production systems have not been reviewed since deployment. Naming the specific unowned duty and its consequence is more effective than describing allocation as incomplete.

A.3.3 Reporting of concerns

WHAT THE CONTROL ASKS FOR

Provide a mechanism for people to report concerns about AI systems, and make sure they know about it and can use it. Concerns may come from staff, from users, or from people affected by system outputs.

WHY IT EXISTS

Problems with AI systems are usually noticed first by whoever is closest to the outputs: the caseworker seeing decisions that look wrong, the customer service agent hearing the same complaint repeatedly. If they have no route to raise it, the pattern goes unreported until it becomes an incident. This is a detection capability, and it is cheap.

HOW TO AUDIT IT

1. Confirm a reporting mechanism exists and identify who can use it, including whether it extends beyond employees.
2. Test awareness by asking staff how they would raise a concern about an AI system's outputs.
3. Check reporting volume. Very low volumes indicate the mechanism is unknown, difficult, or discouraged rather than that nothing is wrong.
4. Examine what happened to concerns that were raised, including whether the reporter received a response.
5. Verify there is no penalty for raising a good-faith concern that turns out to be unfounded, and check whether that is stated.
6. Check whether affected individuals outside the organization can raise concerns about decisions affecting them, and how.
7. Confirm concerns feed into the risk and impact assessment processes rather than being handled in isolation.

EVIDENCE TO COLLECT

- Reporting mechanism description and access routes
- Volume statistics across periods and by source
- Awareness content covering how to raise a concern
- Sample concerns with acknowledgement and outcome records
- External route for affected individuals
- Evidence of concerns feeding risk or impact assessment

HOW TO DOCUMENT IT

Record volume trends by period and by source. Record staff answers on both how to report and what happened when they did, since the second question reveals whether the mechanism has credibility. Note explicitly whether an external route exists for affected individuals.

EXECUTIVE SUMMARY TREATMENT

Suggested language: people affected by the organization's AI decisions have no route to raise a concern about them, and internal concerns raised during the period received no response. Both halves matter: one is a coverage gap and the other is a culture signal that suppresses future reporting.

Annex A.4: Resources for AI Systems

Five controls requiring the organization to know and document what its AI systems depend on: data, tooling, computing, and people.

This category is about recoverability more than about inventory. AI systems have dependencies that cannot be inspected after the fact. Nobody can determine from a deployed model what data trained it, what library versions it was built against, or who understood the choices made along the way. When any of those disappears, the system keeps running and quietly stops being maintainable, explainable, or defensible.

Two tests carry this category. Ask, for a specific deployed model, what data it was trained on, and note whether the answer comes from documentation or from a person's recollection. Then ask how many people can maintain each production system. A count of one is a finding that needs no further explanation.

Quick reference: A.4 Resources

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
A.4.2	Resource documentation	Resource documentation per AI system
A.4.3 AI	Data resources	Data documentation per AI system with dataset identification and versions
A.4.4	Tooling resources	Tooling documentation per AI system with components and versions
A.4.5	System and computing resources	System and computing resource documentation per AI system
A.4.6	Human resources	Human resource requirements per AI system or system type

A.4.2 Resource documentation

WHAT THE CONTROL ASKS FOR

Identify and document the resources required for the AI systems in scope across their lifecycle. Resources here means the data, tooling, computing, and human capability the systems depend on. The requirement is to know what each system needs and relies on.

WHY IT EXISTS

AI systems have dependencies that are invisible from the outside. A model depends on the data that trained it, the pipeline that feeds it, the platform that serves it, and the people who understand it. When any of those disappears without anyone realizing it was a dependency, the system continues running and quietly stops being maintainable.

HOW TO AUDIT IT

1. Obtain the resource documentation and check it covers all four categories: data, tooling, computing, and human.
2. For a sample of AI systems, verify the documentation identifies the specific resources that system relies on rather than describing the estate generally.
3. Test currency against a system that has changed, and check whether its resource record changed with it.
4. Look for dependencies on individuals, which are the most common undocumented resource and the most fragile.
5. Check whether external dependencies are recorded, including third-party models, APIs, and data sources.
6. Verify the documentation is used, by asking how it informed a recent decision.

EVIDENCE TO COLLECT

- Resource documentation per AI system
- AI system inventory for coverage comparison
- Records of external dependencies including third-party models and data
- Evidence of documentation currency after system change
- Key person dependency records

HOW TO DOCUMENT IT

Record, per sampled system, which of the four resource categories are documented and which are absent. Note human dependencies specifically, including how many people can maintain each system, since a count of one is a finding that needs no further explanation.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has not recorded what its AI systems depend on, and a stated number of production systems can be maintained by only one person. Give the count and name the systems.

A.4.3 Data resources

WHAT THE CONTROL ASKS FOR

Document information about the data resources used for AI systems. This covers what data is used, where it came from, what it contains, and what constraints apply to it.

WHY IT EXISTS

Data determines system behaviour more than any other factor, and unlike code it cannot be inspected after the fact to determine what it contained. An undocumented training set means the organization can never afterwards answer whether the data was representative, whether it was lawfully obtained, or whether it contained information it should not have.

HOW TO AUDIT IT

1. For a sample of AI systems, request the documentation of the data used and assess whether it is sufficient to answer basic questions about representativeness and lawfulness.
2. Check that constraints attached to the data are recorded, including licence terms, consent scope, and contractual restrictions on use for training.
3. Verify the documentation identifies specific datasets and versions rather than describing categories of data.
4. Check whether the documentation would allow someone to reconstruct which data a given model version was trained on.
5. Confirm data documentation is retained beyond the life of the system where accountability may require it.
6. Check coverage across the portfolio and identify systems with no data documentation at all.

EVIDENCE TO COLLECT

- Data documentation per AI system with dataset identification and versions
- Licence, consent, and contractual constraint records for datasets
- Linkage between model versions and the data used to produce them
- Retention arrangements for data documentation
- AI system inventory for coverage comparison

HOW TO DOCUMENT IT

Test by asking, for a specific deployed model, what data it was trained on, and record whether the organization could answer from documentation rather than from an individual's recollection. That single test establishes whether this control operates.

EXECUTIVE SUMMARY TREATMENT

Suggested language: for a stated number of models in production, the organization cannot establish what data they were trained on, which means it cannot determine whether the data was lawfully obtained or representative of the population the system now makes decisions about.

A.4.4 Tooling resources

WHAT THE CONTROL ASKS FOR

Document the tooling used for AI systems, including development frameworks, libraries, platforms, and any other components the systems depend on.

WHY IT EXISTS

AI systems are assembled from components the organization did not write and often cannot see into. Undocumented tooling means that when a vulnerability or a licence problem appears in a widely used library, the organization cannot determine which of its systems are affected without searching.

HOW TO AUDIT IT

1. Obtain the tooling documentation and check coverage across the AI portfolio.
2. Verify it identifies specific components and versions rather than naming categories.
3. Check whether dependency information is captured to a depth that would allow a component vulnerability to be located by lookup rather than by search.
4. Test with a recent example. Pick a component vulnerability disclosed in the period and ask how the organization determined its exposure and how long it took.
5. Check licence terms for tooling, particularly where terms restrict commercial use or impose obligations on outputs.
6. Confirm the documentation is maintained as tooling changes.

EVIDENCE TO COLLECT

- Tooling documentation per AI system with components and versions
- Dependency inventories or software bills of materials
- Licence terms for AI tooling and frameworks
- Timeline evidence for a recent component vulnerability response
- Change records showing documentation maintenance

HOW TO DOCUMENT IT

Document the vulnerability response test as a timeline: disclosure date, date exposure was determined, and method used. Record whether the answer came from documentation or from manual investigation, since that difference is the control.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization cannot determine which of its AI systems use a given component, so responding to a disclosed vulnerability requires manual investigation of each system. Give the elapsed time from the recent example.

A.4.5 System and computing resources

WHAT THE CONTROL ASKS FOR

Document the system and computing resources used for AI systems, including the infrastructure that trains, hosts, and serves them.

WHY IT EXISTS

Computing resources for AI are expensive, often externally provided, and frequently provisioned outside normal infrastructure processes because they were needed quickly. That means AI workloads regularly run on infrastructure the organization has not inventoried, secured, or budgeted for.

HOW TO AUDIT IT

1. Obtain the documentation and reconcile it against actual infrastructure, using cloud console listings and expense records rather than the maintained list.
2. Look specifically for AI compute provisioned outside normal processes, which expense records reveal more reliably than inventories.
3. Check whether the documentation identifies where each system runs, including geographic location where that matters for regulatory purposes.
4. Verify capacity and availability arrangements match the criticality of the systems they support.
5. Check that infrastructure supporting AI is subject to the organization's normal security controls, since it frequently is not.
6. Confirm the documentation is maintained as infrastructure changes.

EVIDENCE TO COLLECT

- System and computing resource documentation per AI system
- Cloud console resource listings for reconciliation
- Expense records including corporate card spend on AI compute
- Geographic location records for regulated workloads
- Security control coverage evidence for AI infrastructure

HOW TO DOCUMENT IT

Present the reconciliation as counts: resources documented, resources found independently, and the difference, with the discovery method recorded. List AI compute found through expense records separately, since it is usually both unmanaged and unsecured.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of AI workloads run on infrastructure provisioned outside the organization's normal processes, is not covered by its security controls, and represents a stated annual spend that was not budgeted. The cost figure often achieves what the security argument alone does not.

A.4.6 Human resources

WHAT THE CONTROL ASKS FOR

Document the human resources required for AI systems and their competence requirements, covering the people needed across the lifecycle.

WHY IT EXISTS

AI capability is concentrated in a small number of people in most organizations, and that concentration is rarely visible until someone leaves. This control makes the dependency explicit so it can be managed rather than discovered.

HOW TO AUDIT IT

1. Obtain the documentation and check it identifies the roles and competences needed per AI system or system type.
2. Compare documented need against actual staffing and identify shortfalls.
3. Identify single points of knowledge by asking how many people can perform each critical AI function.
4. Check whether competence requirements are current given how quickly the field moves.
5. Verify that reviewers and approvers are included, not only builders.
6. Check succession and knowledge transfer arrangements for critical roles.

EVIDENCE TO COLLECT

- Human resource requirements per AI system or system type
- Current staffing against documented need
- Knowledge coverage showing how many people can perform each function
- Competence requirements with last review date
- Succession and knowledge transfer records

HOW TO DOCUMENT IT

Record the knowledge coverage analysis as a table of critical function against number of capable staff. Rows showing one are the finding and need no interpretation. Cross-reference to Clause 7.1 and 7.2 where the gap is resourcing or competence rather than documentation.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of AI systems in production depend on a single individual, and the organization has no knowledge transfer or succession arrangement for any of them. Name the systems and describe what would stop working.

Annex A.5: Assessing Impacts of AI Systems

Four controls implementing the requirement that defines this standard. Impact assessment has no counterpart in ISO/IEC 27001 and it asks a question conventional risk assessment structurally cannot answer.

Risk assessment looks inward: what threatens the organization's objectives. Impact assessment looks outward: what the system does to the people subject to it. An AI system can operate exactly as designed, present no risk to the organization, and still cause serious harm to individuals, because those individuals are not the organization and their harm is not its loss. Where you find these two processes merged into one document, the requirement is unmet regardless of how thorough that document is.

Two questions do most of the work in this category. Has an impact assessment ever reached an adverse conclusion? And has any assessment ever changed a system? A process that has assessed everything and stopped nothing is documenting impacts rather than preventing them.

Quick reference: A.5 Impacts

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
A.5.2 AI	AI system impact assessment process	Documented impact assessment process
A.5.3 AI	Documentation of AI system impact assessments	Completed impact assessments for sampled systems
A.5.4 AI	Assessing AI system impact on individuals or groups of individuals	Impact assessments showing group-level analysis
A.5.5 AI	Assessing societal impacts of AI systems	Impact assessments with a distinct societal analysis

A.5.2 AI system impact assessment process

WHAT THE CONTROL ASKS FOR

Establish a process for assessing the potential consequences of AI systems for individuals, groups, and societies. This is the control that implements the requirement set out in Clause 6.1.4.

WHY IT EXISTS

A defined process is what makes assessment consistent and comparable across systems and assessors. Without one, impact assessment reflects the assessor's imagination, which means the systems assessed by cautious people look risky and those assessed by enthusiastic people look safe, regardless of their actual properties.

HOW TO AUDIT IT

1. Obtain the process and confirm it addresses all three populations, treating societal impact as distinct from individual impact.
2. Check that it defines when assessment is required, who performs it, who reviews it, and what happens when significant impact is found.
3. Verify the process is capable of producing an adverse outcome. Ask what would happen if an assessment concluded a system should not be deployed, and whether that has ever occurred.
4. Confirm it defines timing relative to deployment decisions.
5. Check whether the process requires input from anyone representing the affected population, or relies entirely on the judgment of the builders.
6. Verify reassessment triggers are defined.

EVIDENCE TO COLLECT

- Documented impact assessment process
- Criteria determining when assessment is required
- Defined roles for performance and review
- Defined outcomes and escalation for adverse findings
- Evidence of any assessment that changed a deployment decision
- Reassessment triggers

HOW TO DOCUMENT IT

Record whether the process defines a consequence for an adverse finding, and whether an adverse finding has ever occurred. A process that has assessed many systems and never found significant impact is either operating in an unusually benign portfolio or is not capable of producing that finding.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the impact assessment process has never concluded that an AI system presented significant impact, across a stated number of assessments, and no assessment has resulted in a change to a system. The process cannot currently affect an outcome.

A.5.3 Documentation of AI system impact assessments

WHAT THE CONTROL ASKS FOR

Document the results of AI system impact assessments and retain them. The record must be sufficient for someone else to understand what was assessed, what was found, and what was concluded.

WHY IT EXISTS

Impact assessments are the primary evidence the organization considered the people its systems affect. They are what a regulator, a customer, or a court will ask for. An assessment that was performed but not recorded provides no defence and no basis for later reassessment.

HOW TO AUDIT IT

1. Sample completed assessments and evaluate whether the record is sufficient for a reader to understand the reasoning.
2. Check for identified potential harms with supporting reasoning, rather than a template with affirmative answers throughout.
3. Verify assessments record who performed and reviewed them, and when.
4. Confirm assessments identify the specific populations affected rather than describing impact generally.
5. Check retention arrangements and confirm assessments are kept as long as the systems operate and beyond where accountability requires it.
6. Verify assessments are findable, by asking for the one covering a specific named system.

EVIDENCE TO COLLECT

- Completed impact assessments for sampled systems
- Assessment template or format
- Performer and reviewer records with dates
- Retention schedule for assessment records
- Retrieval test result

HOW TO DOCUMENT IT

Assess sampled records for whether they contain reasoning or only conclusions, and quote an example of each. Record the retrieval test with the system requested and the time taken, since assessments that exist but cannot be found provide no assurance.

EXECUTIVE SUMMARY TREATMENT

Suggested language: impact assessments record conclusions without the reasoning behind them, so the organization cannot demonstrate to a regulator or a customer how it determined that its systems were acceptable. Give an example.

A.5.4 Assessing AI system impact on individuals or groups of individuals

WHAT THE CONTROL ASKS FOR

Assess and document the potential consequences of AI systems for individuals and for groups of individuals throughout the system lifecycle. Groups matter separately from individuals because a system can perform acceptably on average while performing badly for a particular population.

WHY IT EXISTS

Aggregate performance conceals differential performance. A system that is accurate overall can be systematically wrong for a subgroup, and the individuals in that subgroup experience the full consequence. Assessing groups separately is the only way that becomes visible before it becomes a pattern of complaints.

HOW TO AUDIT IT

1. Sample assessments and check whether group effects were considered distinctly from aggregate effects.
2. Verify the groups considered are the ones actually relevant to the system's deployment context, rather than a generic list.
3. Check whether the assessment is supported by any evidence of differential performance, or rests on assertion.
4. Confirm the assessment covers the lifecycle rather than a single point, including how impacts might change as the system operates.
5. Check whether identified impacts on individuals were linked to any mitigation.
6. Verify assessment occurred before deployment for a sample, comparing dates.

EVIDENCE TO COLLECT

- Impact assessments showing group-level analysis
- Differential performance measurement supporting the assessments
- Identification of relevant groups per deployment context
- Mitigation records linked to identified impacts
- Assessment dates against deployment dates

HOW TO DOCUMENT IT

Record whether group analysis is supported by measurement or by assertion, since this is the distinction that determines whether the assessment has any evidential value. Where measurement exists, note which groups were measured and which were not.

EXECUTIVE SUMMARY TREATMENT

Suggested language: impact assessments state that the organization's AI systems affect groups equitably without any measurement supporting the claim, and differential performance has never been tested. The assertion is unsupported and could not be defended if challenged.

A.5.5 Assessing societal impacts of AI systems

WHAT THE CONTROL ASKS FOR

Assess and document the potential societal consequences of AI systems throughout their lifecycle. Societal impact means effects beyond the individuals directly subject to the system, such as effects on labour, on access to services, on public discourse, or on the environment.

WHY IT EXISTS

Some AI effects only appear at scale. A system that treats each individual acceptably can still shift outcomes across a whole population, concentrate access, or degrade a shared resource. This is the element of impact assessment most often omitted entirely, usually because it is harder and because nobody in the room represents the affected interest.

HOW TO AUDIT IT

1. Check whether societal impact is addressed at all, as a distinct section rather than folded into individual impact.
2. Assess whether the analysis considers effects at scale rather than repeating the individual analysis in aggregate terms.
3. Check whether the organization considered effects it would not want to find, such as displacement, exclusion, or environmental cost.
4. Verify any input from outside the organization informed the analysis.
5. Check whether societal considerations are proportionate to the system's reach. A system affecting a small internal population warrants less than one affecting the public.
6. Confirm identified societal impacts led to any action.

EVIDENCE TO COLLECT

- Impact assessments with a distinct societal analysis
- External input, research, or consultation informing the analysis
- Records of actions taken in response to societal findings
- Reach or scale information per AI system

HOW TO DOCUMENT IT

Record simply whether societal impact is addressed at all, since in most assessments it is not and stating that plainly is the finding. Where it is addressed, note whether the analysis considers anything the organization would find inconvenient, as assessments that only identify benefits are not assessments.

EXECUTIVE SUMMARY TREATMENT

Suggested language: impact assessments do not consider effects beyond the individuals directly subject to each system, so the organization has not assessed the consequences of deploying its AI at scale. Where the portfolio includes public-facing systems, name them.

Annex A.6: AI System Life Cycle

Nine controls, the largest category, covering objectives and processes for responsible development followed by the lifecycle itself: requirements, documentation, verification and validation, deployment, operation and monitoring, technical documentation, and logging.

Two of these carry disproportionate weight. A.6.2.4 turns on whether validation used data drawn from the environment the system actually operates in, or reused data from the same source that trained it; the second proves nothing about deployment behaviour. A.6.2.6 turns on whether anything other than availability is monitored. AI systems degrade silently, producing confident outputs at an unchanged rate while their accuracy falls, so a system monitored only for uptime is a system whose failure will be reported by its victims rather than by its operators.

A scoping warning for this whole category. Many organizations' processes cover models built from scratch, while their actual AI work consists of fine-tuning and configuring third-party models. Check which the process covers before concluding it is satisfied.

Quick reference: A.6 Life Cycle

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
A.6.1.2 AI	Objectives for responsible development of AI systems	Documented responsible development objectives
A.6.1.3 AI	Processes for responsible AI system design and development	Documented design and development process with responsibility activities
A.6.2.2	AI system requirements and specification	Requirements specifications for sampled systems with dates
A.6.2.3 AI	Documentation of AI system design and development	Design and development documentation per sampled system
A.6.2.4 AI	AI system verification and validation	Defined verification and validation measures and criteria
A.6.2.5	AI system deployment	Deployment plans with pre-deployment criteria
A.6.2.6 AI	AI system operation and monitoring	Monitoring arrangements per system with metrics and frequencies
A.6.2.7 AI	AI system technical documentation	Technical documentation per AI system
A.6.2.8	AI system recording of event logs	Determination of logging phases with rationale

A.6.1.2 Objectives for responsible development of AI systems

WHAT THE CONTROL ASKS FOR

Identify and document the objectives for responsible development of AI systems, and take them into account during development. Objectives make abstract commitments concrete enough to design toward.

WHY IT EXISTS

Responsible development cannot be achieved by intention alone, because the decisions that determine whether a system behaves acceptably are made in technical detail by people who need to know what they are aiming at. Objectives are how a commitment at policy level reaches the person choosing an evaluation metric.

HOW TO AUDIT IT

1. Obtain the documented objectives and assess whether they are specific enough to guide a development decision.
2. Verify developers know them, by asking rather than by checking distribution.
3. Check whether objectives are taken into account in practice, by examining design decisions in a sampled system and looking for their influence.
4. Confirm objectives address the properties that matter for the organization's systems, which may include accuracy, fairness, robustness, explainability, and safety, and check that the selection was reasoned.
5. Look for evidence of trade-offs being made explicitly, since these objectives frequently conflict and resolving them silently is where responsibility is lost.
6. Check objectives are reviewed as the portfolio changes.

EVIDENCE TO COLLECT

- Documented responsible development objectives
- Evidence developers are aware of them
- Design records for sampled systems showing objective influence
- Records of trade-off decisions between competing objectives
- Review records for the objectives

HOW TO DOCUMENT IT

Look for and record explicit trade-off decisions, since their presence is strong evidence the objectives are operative and their absence usually means one objective silently dominated. Record what developers said the objectives were against what is documented.

EXECUTIVE SUMMARY TREATMENT

Suggested language: responsible development objectives exist at policy level but are not known to the people making development decisions, and no record exists of how competing objectives were resolved in any system. Trade-offs are being made implicitly by individuals.

A.6.1.3 Processes for responsible AI system design and development

WHAT THE CONTROL ASKS FOR

Define and document the processes for responsible design and development of AI systems, and apply them throughout the lifecycle.

WHY IT EXISTS

Objectives without process are aspirations. The process is what makes responsible development repeatable across teams and across systems, rather than dependent on which individuals happened to build a given system.

HOW TO AUDIT IT

1. Obtain the process definition and identify the responsibility-related activities at each development stage.
2. Verify the activities occur, by sampling recent development work and looking for their outputs.
3. Check the process applies to all development, including work by contractors, work in business units outside the AI function, and configuration of purchased AI tooling.
4. Assess whether the process is enforced by tooling or gates, or depends on individual discretion.
5. Check whether the process covers systems built by fine-tuning or configuring third-party models, which many processes address only for models built from scratch.
6. Verify the process covers maintenance and retraining, not only initial development.

EVIDENCE TO COLLECT

- Documented design and development process with responsibility activities
- Evidence of activity outputs for sampled development work
- Coverage evidence including contractor and business-unit development
- Gate or tooling configuration enforcing the process
- Process coverage for fine-tuning and configuration work

HOW TO DOCUMENT IT

Sample recent work and record which activities produced evidence and which did not, by stage. Record specifically whether the process covers fine-tuning and configuration of third-party models, since that is where most organizations' current development actually happens.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the responsible development process applies only to models built from scratch, while the organization's current AI work consists almost entirely of fine-tuning and configuring third-party models, which is ungoverned. This reframes an apparently satisfied control as a coverage failure.

A.6.2.2 AI system requirements and specification

WHAT THE CONTROL ASKS FOR

Specify and document the requirements for new AI systems or material enhancements to existing ones. Requirements should cover what the system must do, how well, and under what constraints.

WHY IT EXISTS

Requirements determine what gets built and what gets tested. AI systems are unusually prone to being built without them, because the development process is exploratory and a working prototype can become production without anyone having stated what it was supposed to achieve. Systems without requirements cannot be verified against anything.

HOW TO AUDIT IT

1. Sample AI systems and confirm documented requirements existed before development or acquisition.
2. Check that requirements include performance thresholds specific enough to pass or fail against, rather than directions of travel.
3. Verify requirements cover the properties from the responsible development objectives, not only functional capability.
4. Check requirements state the intended operating conditions and the populations the system is intended for.
5. Confirm requirements were approved by someone accountable rather than assembled by the build team alone.
6. Verify the delivered system was checked against its requirements, linking to A.6.2.4.

EVIDENCE TO COLLECT

- Requirements specifications for sampled systems with dates
- Performance thresholds and acceptance criteria
- Approval records for requirements
- Intended use and operating condition statements
- Verification evidence against requirements

HOW TO DOCUMENT IT

Compare the date requirements were documented to the date development began or the system was acquired. Requirements written afterwards are documentation rather than requirements, and the date comparison evidences this cleanly. Record whether thresholds are specific enough to fail against.

EXECUTIVE SUMMARY TREATMENT

Suggested language: AI systems entered production without documented performance requirements, so there is no threshold against which any of them can be said to be working or failing. Give the count of systems and note that this also prevents meaningful monitoring.

A.6.2.3 Documentation of AI system design and development

WHAT THE CONTROL ASKS FOR

Document the design and development of AI systems, covering the decisions made and the rationale behind them.

WHY IT EXISTS

AI system behaviour cannot be recovered by inspection. Nobody can determine from a trained model what alternatives were considered, why a particular architecture or data source was chosen, or what was known to be a limitation at the time. If it is not written down during development, it is unrecoverable afterwards, and it is exactly what is asked for when something goes wrong.

HOW TO AUDIT IT

1. Sample systems and assess whether the documentation records decisions and rationale or only the final state.
2. Check whether known limitations identified during development were recorded.
3. Verify the documentation identifies the model version it describes.
4. Test usefulness by asking a specific question about a deployed system, such as why a particular data source was chosen, and seeing whether documentation answers it.
5. Check that documentation is produced during development rather than assembled afterwards, by comparing dates.
6. Confirm coverage across the portfolio and identify undocumented systems.

EVIDENCE TO COLLECT

- Design and development documentation per sampled system
- Records of decisions and their rationale
- Known limitation records from development
- Model version linkage
- Document creation dates against development timeline

HOW TO DOCUMENT IT

Record the specific question you asked about a deployed system and whether the documentation answered it. That test measures the documentation's actual value rather than its existence, which is what the control is for.

EXECUTIVE SUMMARY TREATMENT

Suggested language: development documentation records what was built but not why, so for a stated number of production systems the organization cannot explain the design choices that determine how they behave. This is the documentation a regulator asks for first.

A.6.2.4 AI system verification and validation

WHAT THE CONTROL ASKS FOR

Define and use verification and validation measures for AI systems, and document the criteria applied. Verification asks whether the system was built correctly against its specification; validation asks whether it does what it is actually needed to do in its real context.

WHY IT EXISTS

These are different questions and passing one does not imply passing the other. A model can achieve excellent scores on a held-out test set and fail completely in deployment because the test set did not resemble the real input distribution. Validation in context is what catches that, and it is the step most often skipped.

HOW TO AUDIT IT

1. Confirm both verification and validation measures are defined, and check the organization understands the distinction.
2. Obtain the criteria applied and assess whether they are specific enough to fail against.
3. Sample systems and examine the evidence of testing performed, including what data was used.
4. Check whether validation used data representative of the real deployment context or reused development data.
5. Verify differential performance was tested across relevant groups, linking to A.5.4.
6. Check what happened where testing revealed shortfalls, and whether any system was delayed or modified as a result.
7. Confirm re-verification occurs after retraining or material change.

EVIDENCE TO COLLECT

- Defined verification and validation measures and criteria
- Test results for sampled systems with the data used
- Representativeness analysis for validation data
- Differential performance test results
- Records of systems modified or delayed following testing
- Re-verification records after retraining

HOW TO DOCUMENT IT

Record whether validation used data drawn from the real deployment context, and how the organization established that it was representative. This is the technical crux of the control and it is usually asserted rather than demonstrated. Note whether any system was ever changed as a result of testing.

EXECUTIVE SUMMARY TREATMENT

Suggested language: AI systems are tested against data drawn from the same source as their training data rather than from the environment they operate in, so testing does not establish whether they work in practice. Where nothing has ever failed testing, state that as well.

A.6.2.5 AI system deployment

WHAT THE CONTROL ASKS FOR

Document a deployment plan for each AI system and confirm the requirements are met before it goes into use.

WHY IT EXISTS

Deployment is the last point at which anything can be stopped. It is also where the accumulated shortcuts of a development project become production reality. A deployment gate with defined criteria is what converts governance activity into a decision rather than a record.

HOW TO AUDIT IT

1. Confirm deployment plans exist for sampled systems and that they define the criteria to be met before go-live.
2. Verify criteria were confirmed as met, with evidence, rather than assumed.
3. Check for systems deployed with unmet criteria and identify who authorized that.
4. Confirm the deployment plan addresses the operating context: who will use the system, for what decisions, and with what human involvement.
5. Check rollback arrangements exist and whether they have been tested.
6. Verify that deployment was communicated to the people who will rely on the system's outputs.
7. Check whether phased or limited deployment was considered for higher-impact systems.

EVIDENCE TO COLLECT

- Deployment plans with pre-deployment criteria
- Evidence criteria were confirmed met
- Authorization records for deployment with unmet criteria
- Rollback arrangements and test evidence
- Communication records to users of system outputs

HOW TO DOCUMENT IT

List systems deployed with unmet criteria alongside the authorizer for each, since that list demonstrates whether the gate functions as a gate. Record whether rollback has been tested rather than whether it is documented.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of AI systems were deployed with known requirements unmet, authorized by the same people accountable for delivering them. The authorization pattern matters as much as the count.

A.6.2.6 AI system operation and monitoring

WHAT THE CONTROL ASKS FOR

Define and document the arrangements for operating and monitoring AI systems, and carry them out. This covers what is monitored, how often, by whom, and what happens when monitoring shows a problem.

WHY IT EXISTS

AI systems degrade silently. Performance falls as the world the system operates in drifts away from the world it was trained on, and the system continues producing confident outputs throughout. Monitoring is the only mechanism that makes this visible, which makes this the most important control in the lifecycle category.

HOW TO AUDIT IT

1. Confirm monitoring arrangements are documented per system with defined metrics, frequencies, and owners.
2. Verify monitoring actually occurs, by comparing the last measurement date to the required frequency for every production system.
3. Check what is monitored. Availability and latency are not performance; look for output quality, drift, and differential performance.
4. Confirm thresholds are defined that trigger action, and check what happens when they are breached.
5. Examine whether any monitoring result has led to an intervention in the period.
6. Check that monitoring covers third-party and vendor-hosted models, where the organization has less visibility and often none.
7. Verify human oversight arrangements where the system requires them, and check they operate in practice rather than nominally.

EVIDENCE TO COLLECT

- Monitoring arrangements per system with metrics and frequencies
- Monitoring results across multiple periods
- Defined thresholds and escalation paths
- Records of interventions triggered by monitoring
- Monitoring coverage for third-party hosted models
- Human oversight records where applicable

HOW TO DOCUMENT IT

Produce a table of every production AI system against its last performance measurement date and required frequency. Blank and stale rows are the finding and they are usually the majority. Record separately whether any monitoring result has ever triggered an action.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of AI systems in production are not monitored for output quality, only for availability, so the organization would know if they stopped running but not if they stopped working. That contrast communicates the gap faster than any technical description.

A.6.2.7 AI system technical documentation

WHAT THE CONTROL ASKS FOR

Produce and maintain technical documentation for AI systems, sufficient for the people who need to understand, operate, assess, or rely on them.

WHY IT EXISTS

Technical documentation is what allows a system to be assessed by someone who did not build it, which includes auditors, regulators, incoming staff, and customers performing due diligence. It is also increasingly a direct regulatory requirement rather than good practice.

HOW TO AUDIT IT

1. Confirm technical documentation exists per system and identify its intended audience.
2. Assess sufficiency against that audience. Documentation written by builders for builders will not serve an assessor or a customer.
3. Check the documentation covers purpose, intended use, limitations, performance characteristics, and the data used.
4. Verify it is maintained as systems change, comparing revision dates to system change records.
5. Check whether documentation would satisfy the disclosure obligations that apply to the organization.
6. Test findability by requesting the documentation for a specific named system.

EVIDENCE TO COLLECT

- Technical documentation per AI system
- System change records for comparison against documentation revisions
- Applicable disclosure requirements for gap comparison
- Retrieval test result
- Audience or intended-reader definition

HOW TO DOCUMENT IT

Compare documentation content against the specific disclosure obligations that apply to the organization, item by item, since this turns a general adequacy judgment into a concrete gap list. Record revision dates against system change dates.

EXECUTIVE SUMMARY TREATMENT

Suggested language: technical documentation for the organization's AI systems does not contain the information required by regulation applicable to it, and has not been updated since the systems were materially changed. Name the regulation and the missing elements.

A.6.2.8 AI system recording of event logs

WHAT THE CONTROL ASKS FOR

Determine at which phases AI systems should record event logs, and implement that logging. Logs record what the system did, when, on what input, and with what result.

WHY IT EXISTS

Without logs, an AI system's past decisions cannot be examined. When someone challenges an outcome, or a pattern of poor decisions is suspected, the logs are the only evidence of what actually happened. They are also what makes it possible to establish the scope of a problem once one is found.

HOW TO AUDIT IT

1. Confirm the organization has determined which phases require logging and documented the reasoning.
2. Verify logging is implemented per system and check what is actually recorded.
3. Assess sufficiency. Logs recording that a decision was made, without the input or the output, cannot support any later examination.
4. Check retention against the period over which decisions might be challenged, which for consequential decisions may be years.
5. Verify log protection and integrity, since logs supporting contested decisions must be reliable.
6. Check whether logs are reviewed, or only retained.
7. Confirm logging arrangements exist for vendor-hosted models, where the organization may depend on the vendor for this entirely.
8. Check privacy treatment of logs, since decision logs about individuals are themselves personal data.

EVIDENCE TO COLLECT

- Determination of logging phases with rationale
- Logging configuration per AI system
- Sample log records showing recorded content
- Retention configuration against challenge periods
- Log integrity protection evidence
- Vendor logging arrangements and access to them
- Privacy assessment covering decision logs

HOW TO DOCUMENT IT

Record what a log entry actually contains for a sampled system, and assess whether it would allow a specific past decision to be reconstructed. Compare retention to the period over which decisions can be challenged, since a mismatch there is a clean and consequential finding.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization cannot reconstruct decisions made by its AI systems because logs do not record the inputs and outputs, and are retained for a shorter period than decisions can be challenged. Give both the content gap and the retention figures.

Annex A.7: Data for AI Systems

Five controls covering the data used to build AI systems: what may be used, how it is acquired, its quality, its provenance, and how it is prepared.

Every control in this category is AI-specific. Information security has controls for protecting data; it has none for establishing whether data is representative of the population a system will make decisions about, or for recording what was done to it before it became a model. Your ISO 27001 evidence will not help you here.

Representativeness is the quality dimension that matters most and the one conventional data quality frameworks address least. A model trained on data that under-represents a population performs worse for that population, permanently, and no subsequent tuning fixes it. Ask what reference population representativeness was assessed against; in most organizations the question has never been asked.

Provenance is the control that makes every other question answerable later. Once the chain is lost it cannot be reconstructed, and with it goes the ability to demonstrate that data was lawfully obtained or that its use was permitted.

Quick reference: A.7 Data

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
A.7.2 AI	Data for development and enhancement of AI systems	Documented approach to development data
A.7.3 AI	Acquisition of data	Documented data acquisition requirements
A.7.4 AI	Quality of data for AI systems	Documented data quality requirements including representativeness
A.7.5 AI	Provenance of data used in AI systems	Provenance recording process
A.7.6 AI	Data preparation	Documented data preparation methods

A.7.2 Data for development and enhancement of AI systems

WHAT THE CONTROL ASKS FOR

Define and document the organization's approach to the data used to develop and improve AI systems. This covers what data may be used, on what basis, and subject to what constraints.

WHY IT EXISTS

Data is the primary determinant of AI system behaviour and the primary source of legal exposure. Most organizations' AI development uses data collected for other purposes, which raises questions about whether that use is permitted that nobody asks unless a process requires it.

HOW TO AUDIT IT

1. Obtain the documented approach and confirm it addresses permitted sources, permitted uses, and the constraints attached.
2. Check whether it requires the lawful basis for using data in development to be established, rather than assumed from the fact the organization holds it.
3. Sample development datasets and verify the approach was applied, examining what was actually used.
4. Look for use of customer data, employee data, or publicly scraped data, each of which carries distinct constraints that are frequently unexamined.
5. Check whether contractual restrictions on customer data were considered, since agreements often prohibit training use explicitly.
6. Verify the approach covers data used for fine-tuning and evaluation, not only initial training.

EVIDENCE TO COLLECT

- Documented approach to development data
- Dataset records for sampled development work
- Lawful basis assessments for development data use
- Customer agreements containing restrictions on training use
- Records of data source approval decisions

HOW TO DOCUMENT IT

For each sampled dataset record the source, the stated basis for using it in development, and whether that basis was established or assumed. Where customer data is involved, record the contractual position by clause reference, since this is the exposure most likely to become a dispute.

EXECUTIVE SUMMARY TREATMENT

Suggested language: customer data was used to develop AI systems without checking whether the agreements permitted it, and a stated number of the agreements reviewed prohibit that use. Name the affected customers or the revenue they represent.

A.7.3 Acquisition of data

WHAT THE CONTROL ASKS FOR

Determine and document the requirements for acquiring data for AI systems, covering how data is obtained, from whom, and on what terms.

WHY IT EXISTS

Data acquired without defined requirements arrives with unknown properties and unknown permissions. Third-party datasets in particular frequently carry restrictions, uncertain provenance, or content the acquirer would not knowingly use. Acquiring first and examining later means the exposure already exists by the time anyone looks.

HOW TO AUDIT IT

1. Obtain the acquisition requirements and confirm they cover permissions, quality, provenance, and content.
2. Sample acquired datasets and verify requirements were applied before acquisition rather than afterwards.
3. Check licence and usage terms for acquired data, particularly restrictions on commercial or derivative use.
4. Verify the supplier of the data was assessed, linking to A.10.3.
5. Check whether the organization established what the data contains, including whether it includes personal data it did not expect.
6. Confirm acquisition decisions are recorded with an accountable approver.

EVIDENCE TO COLLECT

- Documented data acquisition requirements
- Acquisition records for sampled datasets with dates
- Licence and usage terms for acquired data
- Supplier assessment records for data providers
- Content analysis for acquired datasets
- Approval records

HOW TO DOCUMENT IT

Record the acquisition date against the date requirements were applied, since retrospective assessment is the common pattern. Note any dataset whose licence terms restrict the use the organization is actually making of it, quoting the term.

EXECUTIVE SUMMARY TREATMENT

Suggested language: datasets were acquired and used in production systems without checking their licence terms, and a stated number carry restrictions the organization's use exceeds. Licence exposure is concrete and quantifiable, which makes it act-on-able.

A.7.4 Quality of data for AI systems

WHAT THE CONTROL ASKS FOR

Define and document requirements for the quality of data used in AI systems, and check that data meets them. Quality includes accuracy, completeness, currency, and representativeness of the population the system will operate on.

WHY IT EXISTS

Data quality determines system quality directly and unforgivingly. A model trained on data that under-represents a population will perform worse for that population, and no amount of subsequent tuning fixes it. Representativeness is the quality dimension that matters most for AI and the one conventional data quality frameworks address least.

HOW TO AUDIT IT

1. Obtain the quality requirements and check whether representativeness is addressed alongside conventional dimensions such as accuracy and completeness.
2. Verify quality was assessed against those requirements for sampled datasets, with results recorded.
3. Check whether representativeness was assessed against the actual deployment population rather than assumed.
4. Examine what happened where quality shortfalls were found, and whether any system was delayed or modified.
5. Check whether quality is reassessed over time, since data drifts and a dataset adequate at training may not be adequate for retraining.
6. Verify quality requirements are proportionate to the consequence of the system's decisions.

EVIDENCE TO COLLECT

- Documented data quality requirements including representativeness
- Quality assessment results per dataset
- Representativeness analysis against deployment populations
- Records of action taken on quality shortfalls
- Reassessment records

HOW TO DOCUMENT IT

Record specifically whether representativeness was assessed and against what reference population. This single question distinguishes AI data quality from general data quality and is usually unanswered. Note any quality shortfall that was identified and accepted without action.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has never assessed whether its training data represents the population its AI systems make decisions about, so differential performance across groups is neither prevented nor detectable. Link this to any monitoring or impact assessment findings.

A.7.5 Provenance of data used in AI systems

WHAT THE CONTROL ASKS FOR

Define and document a process for recording the provenance of data used in AI systems. Provenance means where the data came from, how it was collected, what has been done to it since, and by whom.

WHY IT EXISTS

Provenance is what allows every other question about data to be answered later. Whether the data was lawfully obtained, whether consent covered this use, whether a supplier's claims were accurate, and whether a problem found in one dataset affects others all depend on knowing the chain. Once lost it cannot be reconstructed.

HOW TO AUDIT IT

1. Confirm a provenance recording process exists and check what it captures.
2. Sample datasets in production use and ask where each came from, testing whether the answer comes from records or from recollection.
3. Check whether provenance covers transformations applied after acquisition, not only the original source.
4. Verify provenance records persist alongside the data, including through copies into development and test environments.
5. Check whether provenance is sufficient to answer a lawfulness question about a specific dataset.
6. Confirm provenance is recorded for data used in fine-tuning and evaluation as well as initial training.

EVIDENCE TO COLLECT

- Provenance recording process
- Provenance records for sampled datasets
- Transformation and processing history
- Evidence provenance persists through environment copies
- Retention arrangements for provenance records

HOW TO DOCUMENT IT

Test by selecting a dataset in production use and asking for its full provenance, recording whether the answer came from documentation or from a person's memory. Where provenance is incomplete, state specifically what can no longer be established.

EXECUTIVE SUMMARY TREATMENT

Suggested language: for a stated number of datasets in production use the organization cannot establish where the data came from, which means it cannot demonstrate that the data was lawfully obtained or that its use is permitted. This is the finding most likely to matter in a regulatory enquiry.

A.7.6 Data preparation

WHAT THE CONTROL ASKS FOR

Define and document the data preparation methods used, including how data is cleaned, transformed, labelled, and split for training and evaluation.

WHY IT EXISTS

Preparation decisions shape system behaviour as much as model architecture does. How missing values are handled, how categories are defined, how labels are assigned, and how data is split all embed judgments that become properties of the finished system. Undocumented, they cannot be reviewed, reproduced, or corrected.

HOW TO AUDIT IT

1. Obtain the documented preparation methods and check they cover cleaning, transformation, labelling, and splitting.
2. Sample a system and check whether its preparation is documented in enough detail to be reproduced.
3. Examine labelling specifically: who assigned labels, against what definitions, and with what consistency checking.
4. Check how training and evaluation data were split, and whether the split prevents information from the evaluation set influencing training.
5. Look for preparation decisions with potential fairness consequences, such as how records with missing demographic data were handled.
6. Verify preparation is reproducible, since a system that cannot be rebuilt cannot be corrected.

EVIDENCE TO COLLECT

- Documented data preparation methods
- Preparation records per sampled system
- Labelling procedures, definitions, and consistency checking results
- Train and evaluation split methodology
- Reproducibility evidence such as pipeline code and configuration

HOW TO DOCUMENT IT

Record whether the preparation for a sampled system could be reproduced from the documentation alone. Note labelling arrangements in detail, including who did it and whether consistency was measured, since inconsistent labelling is a common and invisible source of poor performance.

EXECUTIVE SUMMARY TREATMENT

Suggested language: data preparation for the organization's AI systems is not documented, so the systems cannot be reproduced, independently reviewed, or corrected if a problem in preparation is later identified. Note any system where labelling was performed without defined criteria.

Annex A.8: Information for Interested Parties

Four controls covering what the organization tells people about its AI: users, the public, those affected by incidents, and interested parties generally.

The characteristic failure is that capability is described and limitations are not. Users receive an account of what a system does and nothing about what it cannot do, which matters because AI outputs arrive with an appearance of authority regardless of their reliability. The most useful test in this category is not a document review: ask actual users what they believe the system does, and compare that to what it does.

A.8.3 carries a distinct exposure. Public statements about accuracy, fairness, or human oversight are commitments, and they are increasingly checked. Select a specific published claim and ask the organization to substantiate it.

Quick reference: A.8 Information

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
A.8.2 AI	System documentation and information for users	User-facing information and documentation
A.8.3 AI	External reporting	External AI statements, disclosures, and reports
A.8.4	Communication of incidents	AI incident communication plan
A.8.5 AI	Information for interested parties	Interested party register with information requirements

A.8.2 System documentation and information for users

WHAT THE CONTROL ASKS FOR

Determine and provide the information users of AI systems need to use them appropriately. This includes what the system does, what it is for, how to interpret its outputs, and what its limitations are.

WHY IT EXISTS

Users cannot use a system appropriately if they do not know what it is doing. AI outputs are particularly prone to misinterpretation because they arrive with an appearance of authority regardless of their reliability. Telling users what the system cannot do is more valuable than telling them what it can.

HOW TO AUDIT IT

1. Identify what information users actually receive and compare it to what they would need to use the system correctly.
2. Check that limitations are communicated, since capability is almost always described and limitations almost never are.
3. Verify users are told how to interpret outputs, including any confidence or uncertainty information and what it means.
4. Ask actual users what they believe the system does and compare to what it does. Divergence here is the finding.
5. Check whether users know what to do when they believe an output is wrong.
6. Verify information is provided in a form users will actually encounter, rather than in documentation they must seek out.

EVIDENCE TO COLLECT

- User-facing information and documentation
- Limitation statements provided to users
- Guidance on interpreting outputs
- Interview notes recording user understanding
- Escalation route for disputed outputs

HOW TO DOCUMENT IT

Record what users told you the system does against what it actually does, close to verbatim. That comparison is the substance of this control and cannot be evidenced from documentation review alone. Note whether limitations are communicated at the point of use or only in reference material.

EXECUTIVE SUMMARY TREATMENT

Suggested language: users of a named AI system believe it does something materially different from what it does, and have not been told its limitations, so they are relying on outputs beyond what the system supports. Give the specific misunderstanding.

A.8.3 External reporting

WHAT THE CONTROL ASKS FOR

Determine and document the organization's approach to reporting externally about its AI systems, and provide the information it has determined or is required to provide.

WHY IT EXISTS

External reporting is how the organization's AI governance becomes visible to customers, regulators, and the public. It is increasingly a regulatory obligation rather than a choice. Reporting also creates commitments: whatever the organization publishes becomes the standard it will be measured against.

HOW TO AUDIT IT

1. Identify what the organization reports externally about its AI and to whom.
2. Check the reporting against the obligations that actually apply to it, and identify gaps.
3. Verify published claims are accurate and supported. Statements about accuracy, fairness, or human oversight are commitments and should be evidenced.
4. Check who approves external AI statements and whether the AI governance function is involved, since marketing-originated claims are a common source of overstatement.
5. Confirm reporting is kept current as systems change.
6. Check whether the organization can substantiate a specific published claim on request.

EVIDENCE TO COLLECT

- External AI statements, disclosures, and reports
- Applicable external reporting obligations
- Approval records for external AI statements
- Evidence substantiating published claims
- Review records keeping statements current

HOW TO DOCUMENT IT

Select a specific published claim and test whether the organization can substantiate it, recording the claim verbatim and the evidence offered. Unsupported public claims are a distinct and serious exposure and this test evidences them directly.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization publicly states that its AI systems are subject to human review, and this could not be substantiated for a stated number of the systems concerned. Quote the published claim. Public statements that cannot be supported carry regulatory and contractual risk beyond the underlying gap.

A.8.4 Communication of incidents

WHAT THE CONTROL ASKS FOR

Determine and document a plan for communicating AI system incidents to the parties who need to know, including affected individuals, customers, and regulators where required.

WHY IT EXISTS

AI incidents have a different shape from security incidents. They are often discovered gradually, may have been causing harm for a long period before detection, and the affected parties may have no relationship with the organization. Deciding in advance who is told what, and when, is the difference between a managed disclosure and an improvised one.

HOW TO AUDIT IT

1. Obtain the plan and confirm it identifies audiences, content, timing, and responsible parties.
2. Check whether affected individuals are included as an audience, distinct from customers.
3. Verify regulatory notification requirements are reflected with their timelines, noting these differ from security breach requirements.
4. Check how the organization would identify who was affected by an AI incident, since this requires decision logging, linking to A.6.2.8.
5. Test against a real incident if one occurred, comparing actual communication to the plan.
6. Confirm the plan addresses incidents involving vendor-supplied models where the organization may learn of the problem late or not at all.

EVIDENCE TO COLLECT

- AI incident communication plan
- Audience identification including affected individuals
- Regulatory notification requirements and timelines
- Records of communication during any actual AI incident
- Capability to identify affected individuals from decision records

HOW TO DOCUMENT IT

Record whether the organization could identify who was affected by a past AI incident, since a communication plan is unusable without that capability. Present any real incident as a timeline of plan against actual.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has no plan for notifying people affected by an AI system failure, and could not identify who was affected because decision records do not retain the necessary information. The two gaps compound: the second makes the first unfixable without changing logging.

A.8.5 Information for interested parties

WHAT THE CONTROL ASKS FOR

Determine and provide the information that interested parties need about AI systems, beyond users and beyond incident communication. This covers the ongoing provision of information to the parties identified under Clause 4.2.

WHY IT EXISTS

Interested parties with no relationship to the organization cannot ask for information they need, and organizations rarely provide it unprompted. This control closes the gap between identifying those parties and actually telling them anything, which is where AI governance most often stops.

HOW TO AUDIT IT

1. Compare the interested party register against the parties actually receiving information, and identify those receiving nothing.
2. Check whether affected individuals receive any information about the AI systems making decisions about them.
3. Verify the information provided matches what those parties were determined to need under Clause 4.2.
4. Check accessibility. Information provided in a form the audience cannot use has not been provided.
5. Confirm a route exists for interested parties to request further information and check whether it is used.
6. Verify information is kept current.

EVIDENCE TO COLLECT

- Interested party register with information requirements
- Information actually provided per party
- Accessibility considerations for the intended audiences
- Request routes and records of requests received
- Currency review records

HOW TO DOCUMENT IT

Present a table of interested party, determined information need, and information actually provided. Empty cells in the final column are the finding and the table makes the pattern visible, particularly the concentration of gaps among parties who cannot ask.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the parties the organization identified as needing information about its AI systems receive none, and people subject to AI decisions are not told that AI was involved. Note whether disclosure is a regulatory requirement in the applicable jurisdictions.

Annex A.9: Use of AI Systems

Three controls addressing the organization as a user of AI rather than as a builder of it. Use carries responsibilities the developer cannot discharge: how a system is deployed, what decisions it is permitted to influence, and what human involvement accompanies it are all determined by the user.

Most organizations use far more AI than they build, and this category is where that asymmetry surfaces. A programme that governs internally built systems thoroughly while saying nothing about the AI tools staff use daily is not a mature programme; it is a narrowly scoped one.

A.9.4 produces findings reliably. Systems get extended to new decision types, new populations, and new geographies without revalidation, because they appear to work. Nothing in an AI system signals that it has left the conditions it was tested under. Compare stated intended use against actual use for every system you sample.

Quick reference: A.9 Use

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [cyb](#) or [ai](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
A.9.2^{ai}	Processes for responsible use of AI systems	Documented responsible use processes
A.9.3^{ai}	Objectives for responsible use of AI systems	Documented responsible use objectives
A.9.4^{ai}	Intended use of the AI system	Intended use statements per AI system

A.9.2 Processes for responsible use of AI systems

WHAT THE CONTROL ASKS FOR

Define and document the processes for responsible use of AI systems. This addresses the organization as a user of AI, whether the systems were built internally or obtained from others.

WHY IT EXISTS

Most organizations use far more AI than they build, and use carries its own responsibilities that cannot be discharged by the developer. How a system is deployed, what decisions it is allowed to influence, and what human involvement accompanies it are all determined by the user, not the builder.

HOW TO AUDIT IT

1. Obtain the documented use processes and check they address deployment context, permitted uses, and human involvement.
2. Verify the processes cover third-party AI, including tools adopted by individual teams.
3. Check whether the processes are applied, by sampling AI systems in use and looking for evidence.
4. Examine what governs staff use of general-purpose AI tools, which is where most usage now occurs.
5. Check whether use processes address the decisions AI systems are permitted to influence and any that require human determination.
6. Verify the processes cover cessation, including how the organization would stop using a system found to be causing harm.

EVIDENCE TO COLLECT

- Documented responsible use processes
- Coverage evidence including third-party and general-purpose AI tools
- Records of process application for sampled systems
- Rules governing which decisions AI may influence
- Cessation or suspension arrangements

HOW TO DOCUMENT IT

Record whether processes exist for general-purpose AI tool use by staff, since this is the largest use category in most organizations and is frequently ungoverned while formal AI systems are well controlled. Note the cessation arrangements, or their absence.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization governs the AI systems it builds but has no process covering the AI tools its staff use daily, which is where the majority of its AI exposure now sits. This reframes an apparently mature programme as narrowly scoped.

A.9.3 Objectives for responsible use of AI systems

WHAT THE CONTROL ASKS FOR

Identify and document the objectives for responsible use of AI systems, and take them into account when using AI.

WHY IT EXISTS

Use objectives are what turn a policy commitment into a standard the deploying team can aim at. Without them, responsible use means whatever the deploying team believes it means, which varies across the organization and cannot be assessed.

HOW TO AUDIT IT

1. Obtain the documented use objectives and assess whether they are specific enough to guide a deployment decision.
2. Check they are known to the teams deploying and operating AI, by asking.
3. Verify they are taken into account, by examining deployment decisions for their influence.
4. Confirm the objectives address the properties relevant to the organization's use context.
5. Check for explicit trade-off decisions where objectives conflict.
6. Verify objectives are reviewed as the use portfolio changes.

EVIDENCE TO COLLECT

- Documented responsible use objectives
- Evidence deploying teams are aware of them
- Deployment records showing objective influence
- Trade-off decision records
- Review records

HOW TO DOCUMENT IT

Record what deploying teams said the objectives were against what is documented. Note whether any deployment decision records show the objectives being applied, since objectives that appear nowhere in decisions are not operative.

EXECUTIVE SUMMARY TREATMENT

Suggested language: responsible use objectives are documented but unknown to the teams deploying AI, and appear in no deployment decision record. Objectives that do not reach the point of decision have no effect.

A.9.4 Intended use of the AI system

WHAT THE CONTROL ASKS FOR

Ensure AI systems are used in accordance with their intended use, including the conditions and limitations the provider specified.

WHY IT EXISTS

AI systems are frequently used for purposes they were not designed or validated for, because they appear to work. A model validated for one population, one decision type, or one context will produce plausible outputs well outside those bounds, and nothing in the system signals that it has left the conditions it was tested under.

HOW TO AUDIT IT

1. For a sample of AI systems, obtain the stated intended use and compare it to actual use.
2. Check whether the intended use is documented at all, since systems used without a stated intended use cannot be constrained to it.
3. Look specifically for scope creep: systems extended to new decision types, new populations, or new geographies without revalidation.
4. Verify that provider-specified limitations for third-party systems are known and observed.
5. Check whether any mechanism detects use outside intended bounds, or whether it relies on the deploying team's discretion.
6. Confirm that extension of use triggers reassessment and revalidation.

EVIDENCE TO COLLECT

- Intended use statements per AI system
- Actual use records or descriptions
- Provider limitation statements for third-party systems
- Records of use extension with revalidation evidence
- Detection arrangements for out-of-scope use

HOW TO DOCUMENT IT

Present intended use against actual use for each sampled system, and record every divergence specifically. This comparison is the whole control and it produces findings reliably, because use creep is almost universal and rarely tracked.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a named AI system validated for one purpose is being used for decisions it was never tested for, affecting a population it was not validated against. Name the system and the divergence. This is among the most direct routes to demonstrable harm and executives recognize it immediately.

Annex A.10: Third-Party and Customer Relationships

Three controls covering how responsibility is divided with third parties, how suppliers are managed, and what the organization owes its customers.

AI value chains involve several parties and the gaps between them are where obligations go unmet. A model provider, a platform host, an integrator, and the deploying organization can each reasonably assume another handles monitoring. Watch for the opposite failure too: a responsibility the organization has formally retained but has no practical means of discharging, such as monitoring a vendor-hosted system it has no visibility into. That is worse than an unallocated responsibility, because it creates assurance that does not exist.

For A.10.3, reconcile the AI supplier register against actual payments rather than against procurement records. AI capability arrives through suppliers nobody classified as AI suppliers, and the expense ledger finds them when the register does not.

Quick reference: A.10 Relationships

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
A.10.2	Allocating responsibilities	Documented responsibility allocation per third-party AI arrangement
A.10.3	Suppliers	Supplier process with AI-specific requirements
A.10.4^{AI}	Customers	Records of AI provided to or used for customers

A.10.2 Allocating responsibilities

WHAT THE CONTROL ASKS FOR

Allocate responsibilities within the AI system lifecycle between the organization and any third parties involved, and document the allocation.

WHY IT EXISTS

AI value chains involve multiple parties, and responsibility gaps between them are where obligations go unmet. A model provider, a platform host, an integrator, and the deploying organization can each reasonably believe another handles monitoring, and none does. Explicit allocation is what closes that.

HOW TO AUDIT IT

1. For AI systems involving third parties, obtain the documented allocation of responsibilities.
2. Check the allocation covers the whole lifecycle, particularly monitoring, incident handling, and updates.
3. Look for gaps where no party is allocated a responsibility, and for overlaps where each assumes the other.
4. Verify the allocation is reflected in the contract, not only in an internal document, since an internal allocation does not bind the third party.
5. Check whether the organization has retained responsibilities it cannot discharge, such as monitoring a system it has no visibility into.
6. Confirm the allocation was communicated to the third party and agreed.

EVIDENCE TO COLLECT

- Documented responsibility allocation per third-party AI arrangement
- Contracts reflecting the allocation
- Lifecycle coverage analysis
- Evidence of agreement by the third party
- Assessment of the organization's ability to discharge retained responsibilities

HOW TO DOCUMENT IT

Present the allocation as a lifecycle table with a column per party, marking each phase. Empty cells are the finding. Record separately any responsibility the organization retained but has no practical means of discharging, since that is a different and often more serious problem.

EXECUTIVE SUMMARY TREATMENT

Suggested language: responsibility for monitoring a named AI system is allocated to the organization while the vendor provides no visibility into the system's performance, so the responsibility cannot be discharged. Retained-but-undisable responsibility is worse than an unallocated one because it creates false assurance.

A.10.3 Suppliers

WHAT THE CONTROL ASKS FOR

Establish a process to ensure the organization's approach to responsible AI is applied to services, products, or materials provided by suppliers. This covers AI suppliers and suppliers whose products contain AI.

WHY IT EXISTS

Most AI now enters organizations through suppliers rather than being built internally. The obligations follow the use, not the origin, which means an organization is accountable for the behaviour of AI it bought as much as for AI it built. Supplier processes designed for conventional software do not ask the questions AI requires.

HOW TO AUDIT IT

1. Confirm the supplier process addresses AI-specific considerations rather than treating AI suppliers as ordinary software suppliers.
2. Check what the process asks about: training data, evaluation results, known limitations, update practices, and the supplier's own governance.
3. Verify AI suppliers are identified. Reconcile against expense records, since AI capability arrives through suppliers nobody classified as AI suppliers.
4. Sample AI suppliers and check assessments were performed before engagement and are current.
5. Check whether the organization obtains the information it needs to meet its own obligations, or accepts supplier refusal to provide it.
6. Verify supplier AI changes are notified and assessed, linking to Clause 8.1.

EVIDENCE TO COLLECT

- Supplier process with AI-specific requirements
- AI supplier register reconciled to expense and procurement records
- Completed supplier assessments with dates against engagement dates
- Information obtained from suppliers about their AI
- Change notification arrangements

HOW TO DOCUMENT IT

Reconcile the AI supplier register against expense records and report the difference, describing what the unregistered suppliers provide. Record where the organization accepted a supplier's refusal to provide information it needs, since that is an accepted gap that should have been a decision.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of suppliers providing AI capability were engaged without any AI-specific assessment, identified by comparing the register to actual payments, and for a named critical supplier the organization holds no information about how the model was built or tested.

A.10.4 Customers

WHAT THE CONTROL ASKS FOR

Determine and document the organization's responsibilities to customers in relation to AI systems it provides to them or uses on their behalf.

WHY IT EXISTS

Where the organization supplies AI, its customers depend on it for information they need to meet their own obligations. Where it uses AI on customers' behalf, its choices affect their exposure. Either way the responsibilities need to be explicit, because customers increasingly ask and increasingly have a regulatory reason to.

HOW TO AUDIT IT

1. Identify where the organization provides AI to customers or uses AI in delivering services to them.
2. Check whether customers are told that AI is involved, and in what terms.
3. Verify the organization provides the information customers need to meet their own AI obligations.
4. Check contractual commitments made to customers about AI, and whether they are met.
5. Examine how customer concerns or complaints about AI outputs are handled.
6. Check whether customer data is used in ways the customer may not expect, particularly for model improvement, and whether that is disclosed and permitted.

EVIDENCE TO COLLECT

- Records of AI provided to or used for customers
- Customer-facing disclosure of AI involvement
- Information packages provided to customers about AI systems
- Contractual AI commitments and evidence of compliance
- Customer complaint records relating to AI outputs
- Disclosure and permission records for customer data used in improvement

HOW TO DOCUMENT IT

Record whether customers are told AI is involved in the services they receive, and compare against contractual and regulatory requirements. Where customer data is used for model improvement, record the disclosure position and the contractual basis, quoting the relevant clause.

EXECUTIVE SUMMARY TREATMENT

Suggested language: customer data is used to improve the organization's AI models without that use being disclosed to customers or permitted by their agreements. Give the number of customers affected. This is simultaneously a contractual, regulatory, and reputational exposure and should be reported as all three.

Glossary

Terms are listed alphabetically. Each is also indexed at the point of first use.

AI system

An engineered system that generates outputs such as predictions, recommendations, content, or decisions, for a given set of objectives. Note that this covers far more than machine learning models, and covers AI embedded inside purchased software as much as AI the organization built.

AIMS

AI Management System. The coordinated set of policies, processes, people, and controls through which an organization manages its AI activity. The word system does not mean software.

Annex A

The set of 38 reference controls attached to ISO/IEC 42001:2023, organized into nine categories numbered A.2 to A.10. As in ISO/IEC 27001, it is a checklist to compare your selected controls against, not a set you must implement wholesale.

Annex B

The implementation guidance accompanying Annex A. It is informative rather than normative, meaning it explains rather than requires, but auditors will reasonably expect your implementation to be recognizable against it.

Continual improvement

Making the management system progressively more suitable, adequate, and effective. Distinct from corrective action, which restores something that broke.

Control

A measure that changes risk. It may be a process, a rule, a technical measure, a contractual term, or a person performing a task on a schedule.

Corrective action

Action to eliminate the cause of a nonconformity so it does not recur. Distinct from correction, which fixes the individual instance.

Documented information

The standard's umbrella term for both documents, which state what should happen, and records, which evidence what did happen. Work out which is meant before deciding whether you have it.

Drift

The gradual divergence between the conditions a model was trained on and the conditions it now operates in. Drift degrades performance silently: the system continues producing confident outputs at an unchanged rate while its accuracy falls.

Fine-tuning

Adapting an existing model using additional data. Legally and practically this is development, not use,

and organizations that describe themselves as AI users while fine-tuning have misclassified their role and under-scoped their obligations.

Impact assessment

An assessment of the potential consequences of an AI system for individuals, groups, and societies. Looks outward at who the system affects, as distinct from risk assessment, which looks inward at what threatens the organization's objectives. The two answer different questions and one cannot substitute for the other.

Interested party

Any person or organization that can affect, be affected by, or perceive itself to be affected by the organization's decisions or activities. For AI this includes people subject to the system's outputs, who may have no relationship with the organization and no way to raise a concern.

Nonconformity

A failure to meet a requirement, whether from the standard, the organization's own policies, or a legal or contractual obligation.

Provenance

The record of where data came from, how it was collected, and what has been done to it since. Once lost it cannot be reconstructed, and with it goes the ability to demonstrate that data was lawfully obtained or that its use was permitted.

Representativeness

The degree to which a dataset reflects the population a system will operate on. The data quality dimension that matters most for AI and the one conventional data quality frameworks address least. A model trained on unrepresentative data performs worse for the under-represented population, permanently.

Residual risk

The risk remaining after controls are applied and working as intended. Must be accepted by the risk owner, not by the AI governance function on their behalf.

Risk owner

The person with the authority and accountability to decide what to do about a specific risk. Must be senior enough to make the decision and to fund its consequence.

Role

The organization's position relative to an AI system: developing it, providing it to others, or using one built by someone else. Determined under Clause 4.1. Obligations follow the role, and many organizations occupy more than one, sometimes for the same system.

Root cause

The underlying reason a failure occurred, as distinct from the failure itself. Human error is a symptom; the cause is whatever made the error likely or made it consequential.

Sampling

Testing a subset of a population and drawing a conclusion about the whole. Record the population, the sample size, and the selection method, or the conclusion cannot be defended.

Statement of Applicability

The document listing all 38 Annex A controls with, for each, whether the organization applies it and the justification for including or excluding it. Usually shortened to SoA. The document certification bodies examine most closely.

Validation

Testing whether a system does what it is actually needed to do in its real operating context. Distinct from verification. A model can pass verification against its specification and fail validation because the specification described the wrong thing or the test data did not resemble reality.

Verification

Testing whether a system was built correctly against its specification. Passing verification says nothing about whether the specification was right.

Workpaper

The auditor's record of what was tested, how, what was found, and what was concluded. Written so a reviewer can follow the reasoning without re-performing the work.

Index of Terms and Concepts

- Acquisition of data, 63
- Actions to address risks and opportunities:
 - general, 11
- AI management system, 7
- AI objectives and planning to achieve them, 15
- AI policy, 9, 34
- AI risk assessment, 12, 25
- AI risk treatment, 13, 26
- AI roles and responsibilities, 38
- AI system, 80
- AI system deployment, 57
- AI system impact assessment, 14, 27
- AI system impact assessment process, 47
- AI system operation and monitoring, 58
- AI system recording of event logs, 60
- AI system requirements and specification, 54
- AI system technical documentation, 59
- AI system verification and validation, 56
- AIMS, 6, 80
- Alignment with other organizational policies, 35
- Allocating responsibilities, 77
- Annex A, 80
- Annex B, 80
- Assessing AI system impact on individuals or groups of individuals, 49
- Assessing societal impacts of AI systems, 50
- Awareness, 19
- Communication, 20
- Communication of incidents, 70
- Competence, 18
- Continual improvement, 31, 80
- Control, 80
- Control of documented information, 23
- Corrective action, 80
- Creating and updating documented information, 22
- Customers, 79
- Data for development and enhancement of AI systems, 62
- Data preparation, 66
- Data resources, 42
- Determining the scope of the AI management system, 6
- Documentation of AI system design and development, 55
- Documentation of AI system impact assessments, 48
- Documented information, 21, 80
- Documented information: general, 21
- Drift, 80
- External reporting, 69
- Fine-tuning, 80
- Human resources, 45
- Impact assessment, 81
- Information for interested parties, 71
- Intended use of the AI system, 75
- Interested party, 81
- Internal audit, 29
- Leadership and commitment, 8
- Management review, 30
- Monitoring, measurement, analysis and evaluation, 28
- Nonconformity, 81
- nonconformity, 32
- Nonconformity and corrective action, 32
- Objectives for responsible development of AI systems, 52
- Objectives for responsible use of AI systems, 74
- Operational planning and control, 24
- Planning of changes, 16
- Processes for responsible AI system design and development, 53
- Processes for responsible use of AI systems, 73
- Provenance, 81
- Provenance of data used in AI systems, 65
- Quality of data for AI systems, 64

Reporting of concerns, 39
Representativeness, 81
Residual risk, 81
Resource documentation, 41
Resources, 17
Review of the AI policy, 36
Risk owner, 81
Role, 81
role or roles, 3
Roles, responsibilities and authorities, 10
Root cause, 81
Sampling, 81
Statement of Applicability, 13, 81
Suppliers, 78
System and computing resources, 44
System documentation and information for users, 68
Tooling resources, 43
Understanding the needs and expectations of interested parties, 5
Understanding the organization and its context, 3
Validation, 82
Verification, 82
Workpaper, 82